Implementación de un SOC Nivel 1: Caso C05 PagoClaro Fintech S.A.S.

Nelson Enrique Sierra Pérez

Unidades Tecnológicas de Santander

Ingeniería de Sistemas

Ética del Hacking / Ciberseguridad Defensiva

Docente: Julián Barney Jaimes Rincón

21 de octubre de 2026

Resumen

Este informe técnico presenta el diseño y las pruebas defensivas de un Centro de Operaciones de Seguridad de Nivel 1 (SOC N1) para el caso académico C05, PagoClaro Fintech S.A.S. Describe el alcance, la arquitectura del laboratorio, la supervisión con Wazuh, la protección de endpoints mediante Kaspersky, la propuesta de gestión de incidencias con GLPI, la comparación de firewalls NGFW, el manual operativo, el presupuesto y la planificación de implementación. Se distinguen controles documentados de evidencias realmente verificadas. La prueba controlada EICAR demostró bloqueo local y recolección de registros, sin evidenciar compromiso real ni correlación personalizada concluida. Se desarrollan anexos de inventario, riesgos, procedimientos y trazabilidad, con limitaciones explícitas para facilitar una evaluación reproducible.

Palabras clave: SOC N1, Wazuh, EDR, ciberseguridad, gestión de incidentes, PagoClaro.

Resumen ejecutivo

Alcance, resultados y costo del SOC N1

PagoClaro Fintech S.A.S. es un caso académico de pasarela de pagos y billetera digital de diez empleados y veinte equipos. Su principal necesidad es reconocer tempranamente abusos de credenciales, cambios no autorizados en la API de pagos y actividad anómala en infraestructura cloud, con una respuesta trazable y proporcional al riesgo. (Unidades Tecnológicas de Santander, 2026)

Solución y delimitación

El proyecto combina un diseño de segmentación por VLAN y VPN sede–nube, SIEM Wazuh, protección Kaspersky Next EDR Optimum, un modelo de GLPI para incidentes, evaluación técnica de tres NGFW y procedimientos operativos N1. La implementación se concentró en equipos representativos de VirtualBox; la flota completa y el firewall físico son objetivos de despliegue, no elementos ya instalados. (Sierra Pérez, 2026d; Sierra Pérez, 2026e; Sierra Pérez, 2026g)

Hallazgos verificables

Wazuh recibió registros de endpoints y se documentaron FIM, SCA, inventario de vulnerabilidades y reglas de análisis. Kaspersky bloqueó la descarga del archivo de prueba EICAR el 21/10/2026; el evento Windows 302 apareció en el pipeline de Wazuh, aunque no se acreditó el disparo de la regla propia 100510. La nube GLPI, restauración y los seis tickets completos no están certificados con evidencia propia. (Sierra Pérez, 2026e; Sierra Pérez, 2026f)

Viabilidad financiera

El escenario proyectado de Fase 7 estima CAPEX COP 48.223.427 y OPEX COP 4.503.673/mes, frente a topes COP 70 millones y COP 5 millones mensuales. El TCO incremental de 36 meses es COP 210.355.672, bajo supuestos de carga laboral compartida, costos publicados y parámetros de operación. No equivale a compra o contrato real. (Sierra Pérez, 2026i)

Tabla 1

Alcance, resultados y costo del SOC N1

Resultado	Lectura ejecutiva
SIEM/EDR	Pruebas de laboratorio existentes; integración Kaspersky → Wazuh de registro bruto
NGFW	FortiGate 80F recomendado; selección académica, no adquisición
GLPI / seis tickets	Diseño definido, ejecución propia no acreditada
Presupuesto	Cabe en topes bajo asignación N1 parcial; turnos completos requerirían mayor OPEX

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Caso y alcance

Perfil operativo y activos protegidos

El caso C05 simula una fintech de modalidad híbrida, madurez de seguridad media-alta y servicios transaccionales sobre infraestructura pública IaaS. Su API recibe solicitudes de pago, mientras el bastión y los servidores internos soportan accesos administrativos, respaldo y réplica de bases. Se adopta la base del parcial sin alterar su distribución original. (Unidades Tecnológicas de Santander, 2026)

Superficie de exposición

Los datos financieros, identificadores de clientes y credenciales privilegiadas exigen separación estricta de funciones. La red empresarial propuesta contiene 8 estaciones Win11, 3 portátiles Win11, 5 portátiles macOS y 4 servidores Ubuntu. Router/NGFW, switch y puntos de acceso no consumen las veinte posiciones de inventario. Los componentes del SOC son infraestructura adicional. (Sierra Pérez, 2026b)

Servicios críticos

El orden de criticidad del diseño sitúa API de pagos, núcleo transaccional, base de datos, bastión y material criptográfico por delante de las estaciones de soporte. Se usa CIA de 1 a 3 y criticidad igual al máximo de confidencialidad, integridad y disponibilidad; esta escala favorece un análisis uniforme y no sustituye clasificación contractual. (Sierra Pérez, 2026b)

Tabla 2

Perfil operativo y activos protegidos

Tipo de activo	Cantidad	Distribución funcional
Windows 11	11	8 estaciones de operaciones y soporte; 3 portátiles de gerencia y cumplimiento
macOS	5	Desarrollo y mantenimiento
Ubuntu Server	4	Bastión, réplica BD, aplicación, backup
Servicios cloud	Fuera del conteo	API de pagos y núcleo transaccional

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Objetivos, límites y criterios de aceptación

El objetivo general es diseñar y demostrar un SOC N1 reproducible: telemetría centralizada, detección con herramientas defensivas, triage documentado, escalamiento controlado y un marco presupuestal sostenible. La competencia evaluada es operativa y documental, no la exposición deliberada de sistemas ni la construcción de una defensa certificada. (Unidades Tecnológicas de Santander, 2026)

Dentro del alcance

El laboratorio local comprende un Wazuh todo-en-uno en Ubuntu Server, Windows con EDR y agente SIEM y un agente Linux de prueba. Se generan cambios de integridad y accesos de prueba controlados y se visualiza la detección EICAR. Se diseñan los restantes dieciocho despliegues, el esquema GLPI y la arquitectura NGFW sin atribuirles ejecución. (Sierra Pérez, 2026a; Sierra Pérez, 2026e; Sierra Pérez, 2026f)

Fuera del alcance

No se compra ni instala un NGFW real, no se realizan pruebas sobre entornos ajenos, no se replica un procesamiento real de pagos y no se interviene la VPC de terceros. La integración automática Wazuh–GLPI no es requisito base; se prioriza registro manual. La ciberseguridad transaccional empresarial real, incluida certificación PCI DSS, queda expresamente excluida del piloto. (PCI Security Standards Council, 2024; Unidades Tecnológicas de Santander, 2026)

Aceptación objetiva

Los criterios de aceptación separan: (a) inventario y arquitectura coherentes; (b) agente conectado y eventos reproducibles; (c) telemetría útil de FIM/SCA/CVE; (d) evidencia EDR local y recepción en SIEM; (e) gestión GLPI y tickets propios; (f) tres ofertas comerciales verificables; (g) flujos de respuesta y evaluación económica. No debe marcarse «cumplido» por el solo hecho de redactar un documento.

Tabla 3

Objetivos, límites y criterios de aceptación

Nivel de prueba	Ejemplo verificable
Diseño	Diagrama de red, matriz de riesgos, plan de retención
Ejecución	Servicio activo, agente conectado, evento y hora
Eficacia	Detección + clasificación correcta + respuesta registrada
Producción	Aprobación, operación repetible y evidencia de capacidad total

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Marco ético y legal aplicado

Se emplea la autorización documental de laboratorio de PagoClaro C05. El archivo contiene alcance, pruebas permitidas, prohibiciones, segregación de datos y reglas de detención; además especifica que la autorización no se vuelve efectiva hasta validación por el docente. No se adjunta una firma comprobada. (Sierra Pérez, 2026a)

Autorización y responsabilidad

Las pruebas se limitan a VMs de propiedad del estudiante, identidades ficticias y archivos EICAR de demostración. Queda prohibida la captura de credenciales de terceros, los ataques contra sistemas ajenos, las IP públicas reales en evidencias y la difusión de datos de pago auténticos. La normativa de referencia incluye Ley 1273/2009 y Ley 1581/2012. (Sierra Pérez, 2026a; Unidades Tecnológicas de Santander, 2026)

Gobernanza de datos

Para una fintech, Ley 1266/2008, PCI DSS 4.0.1 y las prácticas de NIST CSF 2.0 orientan trazabilidad, mínimo privilegio, registro de eventos y tratamiento de incidentes. Se citan como marco de diseño, sin afirmar cumplimiento formal ni cobertura regulatoria completa. (National Institute of Standards and Technology, 2024; PCI Security Standards Council, 2024)

Preservación de evidencia

Las pruebas deben conservar fecha/hora normalizadas (America/Bogota), nombre del endpoint, usuario de laboratorio, fuente de log, resultado, hash cuando corresponda y medidas realizadas. Una captura aislada no sustituye un registro exportado; se evita manipular originales y se documentan las transformaciones de anonimización.

Tabla 4

Marco ético y legal aplicado

Regla operativa	Aplicación a C05
Minimización	Usar muestras y capturas sin credenciales ni valores financieros
Segregación	N1 observa y clasifica; N2/TI ejecuta acciones de alto impacto
Detención	Ante riesgo fuera de alcance, suspender prueba y comunicar al docente
Trazabilidad	Distinguir eventos reales, simulados y propuestos

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Matriz de riesgos y prioridades del caso

La matriz propia presenta diez riesgos con probabilidad (P), impacto (I) y nivel P×I de 1 a 25. El inventario y las amenazas se vinculan a procesos de pago, autenticación, respaldo, gestión de identidades e integridad de código. Estas calificaciones son académicas y deben revisarse al identificar exposición real y controles implantados. (Sierra Pérez, 2026c)

Riesgos críticos

R-01: acceso administrativo anómalo por VPN, 20/25; R-04: compromiso de API de pagos, 20/25. Se priorizan tanto por probabilidad como por potencial de interrumpir transacciones o exponer sesiones. La selección NGFW debe facilitar VPN autenticada, segmentación y logs hacia el SIEM. (Sierra Pérez, 2026c; Sierra Pérez, 2026g)

Riesgos altos

Cambio de configuración de API, privilegios de base, acceso indebido, phishing, ransomware y pérdida de registros se mantienen en la banda alta. FIM y análisis de logs detectan alteraciones; un control documental no demuestra por sí solo contención o restauración. (Sierra Pérez, 2026c; Wazuh, s. f.)

Tabla 5

Matriz de riesgos y prioridades del caso

Riesgo	**P×I**	**Control prioritario**
R-01 VPN administrativa anómala	20	Autenticación fuerte, logs VPN y correlación
R-04 API de pagos comprometida	20	WAF, IPS, logs API, segmentación
R-02 Cambio API no autorizado	15	FIM, gestión de cambios, rollback autorizado
R-03 Cuenta privilegiada nueva	15	Auditoría de privilegios, aprobación dual
R-09 Pérdida de logs	12	Retención, alertas sobre pipeline, respaldo

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Nota de evidencia. La totalidad de los diez riesgos se integra en el Anexo B a partir de Matriz_Riesgos_C05(1).xlsx.

Arquitectura

Topología empresarial propuesta

El diseño integra el tráfico corporativo a través de un NGFW, un switch administrable, dos puntos de acceso y una VPN IPsec hacia la VPC transaccional. Se proponen redes diferenciadas para usuarios, servidores y administración. El gateway físico y la VPN son elementos de la solución objetivo, no del laboratorio ya implementado. (Sierra Pérez, 2026d)

Justificación

Las estaciones no deben contactar directamente la base de transacciones; el bastión funciona como punto único de administración y el registro de eventos se centraliza con mínimo privilegio. El WAF propuesto complementa al NGFW en la protección específica de la API; ambos deben producir telemetría sin contenido financiero sensible. (Sierra Pérez, 2026d; Sierra Pérez, 2026g)

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Laboratorio representativo en VirtualBox

El entorno local emplea red Host-only 192.168.56.0/24, complementada con NAT exclusivamente para actualizaciones o conexiones de prueba autorizadas. En la documentación original se propusieron WAZUH-C05, PC-C05-01 y SRV-C05-APP como identidades de referencia; las capturas de campo pueden reflejar hostnames operativos distintos y se citan con su nombre visible. (Sierra Pérez, 2026a; Sierra Pérez, 2026d)

Recursos del nodo central

La rúbrica ofrece como referencia una VM Wazuh de 4 vCPU, 8 GB RAM y 50 GB para 1–25 agentes y 90 días de alertas. El dimensionamiento real depende de EPS, reglas, campos almacenados y costo de indexación; no se extrapola linealmente sin medición. (Unidades Tecnológicas de Santander, 2026; Wazuh, s. f.)

Alcance de las pruebas

Se observan agentes identificados como Windows-Agent y Ubuntu-Agent; la evidencia más reciente muestra Windows activo y Ubuntu desconectado. Por ello, la cobertura piloto es parcial y debe recuperarse el endpoint Linux antes de dar por validada la telemetría cruzada. (Sierra Pérez, 2026e)

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Segmentación, puertos y flujo de registros

En producción se proponen VLAN 10 Operaciones (192.168.10.0/24), VLAN 20 Servidores (192.168.20.0/24) y VLAN 30 Gestión (192.168.30.0/24). El acceso a la VPC por VPN se limita a aplicaciones y rutas autorizadas. La simulación Host-only no demuestra una configuración real de VLAN del switch o del NGFW. (Sierra Pérez, 2026d)

Pipeline

La fuente emite un evento; el collector lo transporta; el decoder determina campos normalizados; la regla evalúa contexto y severidad; el indexer lo almacena; el panel permite triage. El identificador y la fecha de cada salto son esenciales para demostrar correlación, especialmente con Kaspersky. (Wazuh, s. f.)

Privacidad

Los mensajes pueden contener rutas, cuentas y objetos de red. Se filtran datos personales innecesarios antes de exportarlos al proyecto y se define un control de acceso por rol al índice de seguridad.

Tabla 6

Segmentación, puertos y flujo de registros

Origen → destino	Servicio	Propósito / restricción
Usuarios → App	443/TCP	Acceder a la aplicación; no a BD
Bastión → Servidores	22/TCP	SSH con usuarios autorizados
Agentes → Wazuh	1514/TCP	Transporte de registros del agente
Agentes → Wazuh	1515/TCP	Registro de agente, acceso controlado
N1 → Consolas	HTTPS	Paneles restringidos con MFA
NGFW → VPC	IPsec	Túnel con reglas de rutas y subredes
NGFW → Wazuh	syslog	VPN, IPS, AV, bloqueos y auditoría

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Dimensionamiento, disponibilidad y retención

El diseño objetivo incorpora veinte endpoints con agentes Wazuh, mientras los dispositivos perimetrales producen syslog. Se prevé retención operativa de 90 días en Wazuh y archivo de 12 meses, sujeto a verificación de volumen, almacenamiento y restauración. La ejecución efectiva de este esquema no quedó probada en el laboratorio. (Sierra Pérez, 2026e)

Modelo de capacidad

La estimación básica utiliza eventos por segundo (EPS) × tamaño promedio del documento indexado × 86.400 segundos × días × factor de indexación y réplica. Ejemplo ilustrativo: 10 EPS × 1 KB × 86.400 × 90 ≈ 77,8 GB de evento lógico antes de índices y réplicas. No debe confundirse con un valor medido. (Wazuh, s. f.)

Resiliencia y control

El nodo único de SIEM no aporta alta disponibilidad. Se propone respaldar configuraciones, reglas, claves de enrolamiento con custodia segura, templates de índices y lista de agentes. Prueba de restauración y documentación RTO/RPO son hitos de aceptación antes de producción.

Integración cloud

La nube transaccional exige delimitar responsabilidades: infraestructura física del proveedor, sistemas operativos administrados por TI, seguridad de red, protección de secretos, bases y registros de aplicaciones. Una VPC ilustrada en un diagrama no certifica que exporta logs. (Sierra Pérez, 2026d)

Tabla 7

Dimensionamiento, disponibilidad y retención

Indicador	**Meta de diseño**	**Estado**
Flota agentada	20 activos	Piloto representativo, no masivo
Retención consultable	90 días	Política documentada
Archivo seguro	12 meses	No acreditado
Alta disponibilidad SIEM	Evaluar cluster / backup	No implementado

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Siem wazuh

Despliegue y servicios centrales

Wazuh separa agentes, servidor de análisis, indexer y dashboard. En el laboratorio se instaló sobre Ubuntu Server una instancia de trabajo identificada como wazuh-c05; las capturas disponibles sustentan actividad del manager y acceso al análisis de alertas. El enfoque todo-en-uno simplifica pruebas con veinte agentes objetivo, pero no representa un clúster productivo resiliente. (Sierra Pérez, 2026e; Wazuh, s. f.)

Trazabilidad de ejecución

Los comandos documentados incluyen systemctl is-active wazuh-manager y agent_control -l. El primero devolvió active en un punto de observación; el segundo listó un agente Windows activo y uno Ubuntu desconectado. Esta diferencia entre servicio central y estado de endpoint impide concluir disponibilidad de toda la plataforma. (Sierra Pérez, 2026e)

Higiene del SIEM

El hardening previsto contiene reloj sincronizado, firewall restringido, mínimos privilegios, credenciales rotadas, TLS en el panel y revisión del espacio del indexer. El entorno de laboratorio exige eliminar credenciales de las capturas exportadas.

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Alta de agentes y cobertura por sistema

El inventario permite distinguir los activos objeto de monitoreo y el pequeño conjunto realmente desplegado. La arquitectura prevé 11 Windows, 5 macOS y 4 Ubuntu Server; no hay evidencia de instalación de veinte agentes, y la compatibilidad exacta de la edición Kaspersky para macOS debe verificarse por release. (Sierra Pérez, 2026b; Sierra Pérez, 2026e)

Validaciones mínimas

Un agente se acepta cuando está enrolado, reporta heartbeat, transmite al menos un evento verificable con su ID y recibe políticas previstas. La prueba debe registrar hostname, versión, sistema operativo, IP privada de laboratorio, hora local y estado de comunicación. (Wazuh, s. f.)

Plan de despliegue

Se plantearon piloto de dos equipos y tres olas de seis equipos adicionales para completar veinte. El despliegue requiere ventana aprobada, canal de reversión, test de recolección y comprobación de impacto sobre el endpoint. Los servidores cloud administrados requieren distinguir configuración de agente del servicio gestionado. (Sierra Pérez, 2026e)

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

FIM, controles de integridad y evidencia

El módulo FIM realiza comparación de atributos y hashes de rutas vigiladas y avisa de cambios, altas o borrados. Para C05 el recurso de mayor interés es la configuración del API de pagos; el control debe distinguir despliegues aprobados de alteraciones no programadas. La sensibilidad crece cuando el archivo contiene parámetros de conexión o llaves (nunca incluidos en evidencias). (Wazuh, s. f.)

Prueba documentada

Las imágenes F02_07 y F02_08 muestran la modificación de un recurso de prueba y la alerta FIM. Eso acredita el funcionamiento del flujo de cambio a alerta en el entorno representativo, pero no el monitoreo de un servidor productivo de transacciones. (Sierra Pérez, 2026e)

Triage operacional

N1 valida ruta, evento, hash antes/después, usuario, proceso y ventana de cambio. Si existe cambio autorizado se documenta y clasifica como actividad esperada; si no, preserva evidencia y comunica a N2 para contención autorizada. Una alerta FIM por sí sola no equivale a intrusión.

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

SCA, exposición CVE y reglas personalizadas

Security Configuration Assessment contrasta el sistema con pruebas de postura y agrupa controles aprobados y fallidos. El inventario de vulnerabilidades correlaciona software instalado con referencias CVE. Ambos resultados son señales para priorizar hardening, no resultados de explotación ofensiva. (Wazuh, s. f.)

Verificación documental

Hay capturas de SCA, vulnerabilidades y detalle de un CVE (F02_09 a F02_11), y de tres reglas locales ID 100501–100503 (F02_12 a F02_14). El fichero local_rules.xml mostrado en una sesión contiene tres reglas sobre API, PostgreSQL y VPN, pero no demuestra disparos positivos de las tres. (Sierra Pérez, 2026e)

Reglas y pruebas

100501 contempla cambio crítico del archivo de configuración de la API; 100502 se orienta a creación de cuentas con privilegios PostgreSQL; 100503 a acceso administrativo VPN desde país inusual. La eficacia de cada regla exige prueba con log consistente con decoder/field, evento correlacionado y evidencia del ID final, evitando reportar log importado como alerta personalizada exitosa.

Tabla 8

SCA, exposición CVE y reglas personalizadas

Regla	Condición prevista	Severidad
100501	Cambio en /opt/pagoclaro/api/config/.env	12 (diseño)
100502	CREATE ROLE/USER con SUPERUSER	12 (diseño)
100503	VPN admin + país diferente de CO	12 (diseño)

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Respuesta activa, dashboards y trazabilidad

Active Response de Wazuh permite ejecutar acciones a partir de reglas; para un SOC N1 el uso debe restringirse a comandos aprobados, pruebas reversibles y equipos bajo alcance. El proyecto incluye capturas de una prueba de respuesta activa y de su registro, además del tablero de threat hunting asociado a reglas C05. (Sierra Pérez, 2026e; Wazuh, s. f.)

Controles preventivos

Antes de bloquear un origen, confirmar que no pertenezca a gateways, infraestructura de monitoreo o servicios esenciales. Para un fintech un bloqueo erróneo puede impedir el procesamiento de pagos. Toda acción automática requiere supresión de falsos positivos, reversión temporizada y revisión de alertas derivadas.

Tablero y causalidad

F02_17 y F02_18 muestran superficies de búsqueda y reglas. Se exige contrastar hora, rule.id, agent.name, decoder.name, full_log y severidad. La captura de un tablero sin contexto no sustenta un resultado específico de contención. El ejemplo EICAR posterior usa decoder general Windows, no prueba de la regla Kaspersky 100510. (Sierra Pérez, 2026f)

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Edr/xdr kaspersky

Edición, prueba y cobertura inicial

En C05 se utilizó Kaspersky Next EDR Optimum bajo licencia de evaluación. Su propuesta tecnológica combina protección antimalware, investigación EDR y controles de superficie de ataque; la decisión es coherente con un entorno pequeño y una consola cloud. No se extrapola la prueba gratuita a la cobertura permanente de veinte activos. (Kaspersky, s. f.; Sierra Pérez, 2026f)

Licencia y consola

La evidencia muestra licencia de prueba con vencimiento el 21/11/2026 a las 19:00 UTC−5 y capacidad comercial de cien equipos (con 2 unidades indicadas como consumidas en una de las capturas). La consola registra un endpoint Windows 11 llamado NELSON en estado correcto, con el perfil de seguridad C05 asignado. (Sierra Pérez, 2026f)

Edición escogida

Se priorizó EDR Optimum frente a protección puramente antivirus por su potencial de investigación y respuesta guiada. La adopción real exige comparación de licencias para 20 activos, compatibilidad macOS/Ubuntu, soporte local, retención EDR, MFA y condiciones de renovación. (Kaspersky, s. f.)

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Políticas, acciones y excepción mínima

El perfil «C05 - Windows - Protección EDR» se muestra vinculado al endpoint en la consola. Las capturas reflejan módulos de protección de archivos, correo, web, comportamiento y exploits; también se configuró una regla de prevención de ejecución «Prueba EDR C05» con acción de registro, no bloqueo de ejecución. (Sierra Pérez, 2026f)

Lógica de prevención

Registrar y bloquear no son equivalentes. En la prueba inicial se eligió «Solo añadir al registro de eventos», por lo que esa regla no garantiza impedimento de ejecución. El bloqueo posterior de EICAR procede del módulo de protección web/antimalware, no debe atribuírsele a la regla de prevención. (Sierra Pérez, 2026f)

Exclusiones justificadas

No se dispone de exportación probatoria de un conjunto detallado de exclusiones aprobadas. La política recomendada es excluir solo rutas o procesos estrictamente necesarios después de revisar riesgo y ticket de cambio. Nunca excluir de forma genérica el directorio de API, bases de datos ni repositorios de código por motivos de rendimiento.

Tareas y actualización

El documento de Fase 3 distingue políticas y tareas previstas de las verificadas. La prueba de efectividad de actualización debe incluir nombre de tarea, última ejecución, firma y resultado por endpoint; una pantalla de configuración no confirma cumplimiento general.

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

EICAR, Windows EventChannel e ingreso a Wazuh

El 21/10/2026 Kaspersky bloqueó desde Chrome la descarga del archivo oficial EICAR-Test-File. El informe local mostró «Descarga denegada» y «Objeto malicioso detectado» a las 11:34 (America/Bogota). PowerShell recuperó el mensaje en el canal «Kaspersky Endpoint Security», proveedor avp, Event ID 302. (Sierra Pérez, 2026f)

Recepción en SIEM

El agente Wazuh Windows incluyó el canal Kaspersky Endpoint Security en ossec.conf. El archivo archives.json contiene un registro con EICAR-Test-File y campos Windows EventChannel. Una captura posterior de alerts.json relaciona el dato con una regla genérica Windows ID 60011, nivel 5. Se acredita la recepción, no el disparo personalizado 100510. (Sierra Pérez, 2026f)

Regla propuesta

La regla 100510, nivel 12, pretende casar win.system.channel con Kaspersky Endpoint Security y win.eventdata.message con EICAR-Test-File. En la sesión se observó una modificación de local_rules.xml sin prueba final positiva de activación: requiere ensayo de decoder, recarga, coincidencia y comprobación de alertas. (Sierra Pérez, 2026f)

Interpretación de seguridad

EICAR no es software malicioso real. La detección prueba un mecanismo preventivo y una ruta de log; no demuestra compromiso, propagación, pérdida de datos ni cuarentena de ransomware.

La evidencia visual de este apartado se incorpora en el apéndice de figuras del laboratorio.

Glpi en la nube

Diseño de la mesa de servicios e inventario

Para la Fase 4 el diseño contempla GLPI accesible por HTTPS, roles diferenciados, categorías ITIL, SLA/OLA, formularios de incidentes, correo SMTP, 20 activos, base de conocimiento, tableros y restauración. Estos módulos se definen en la rúbrica como evidencias prácticas y su configuración requiere capturas o exportaciones propias. (GLPI Project, s. f.; Unidades Tecnológicas de Santander, 2026)

Modelo organizacional

Entidad raíz PagoClaro Fintech; grupos SOC N1, SOC N2, TI y solicitantes; perfiles Administrador, Técnico, Supervisor y Autoservicio. Categorías mínimas: malware/EDR, FIM, autenticación, VPN, vulnerabilidades, API/BD y uso de dispositivos. Cada ticket relaciona activo, impacto, urgencia, severidad, responsable y cronología.

Gestión de cumplimiento

Las prioridades críticas deben propagar SLA de atención y resolución; las OLA delimitan las obligaciones internas del N1 y N2. La plataforma permite vincular categorías jerárquicas, plantillas y grupos responsables. La operación exige configurar tareas automáticas y comprobar que los correos realmente llegan. (GLPI Project, s. f.)

Base de conocimiento

Los nueve PB-01 a PB-09 y las guías de restablecimiento, VPN y recuperación son la fuente de procedimientos del N1. Su redacción existe como documentos, pero la publicación en GLPI no fue demostrada con capturas propias.

Tabla 9

Diseño de la mesa de servicios e inventario

Módulo	Diseño	Evidencia propia disponible
Entidades/perfiles	Separación de privilegios y atención	No acreditada
SLA/OLA/plantillas	Priorización e incidentes repetibles	No acreditada
Inventario/base de conocimiento	20 activos y 12 artículos previstos	Documental, no alta comprobada
Backup/restore/correo	Continuidad y notificación	No acreditada

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Integración operativa y brecha de evidencia

La demostración GLPI de una compañera ilustra la interfaz de tickets, categorías y activos, pero no certifica que la instancia propia de PagoClaro C05 contenga esas configuraciones. Por integridad académica el presente informe no atribuye una instancia ni correos recibidos al estudiante sin evidencias. (Sierra Pérez, 2026i)

Flujo objetivo de una alerta

N1 recibe alerta en Wazuh o Kaspersky, contrasta activo/usuario/horario, registra un ticket manual con plantilla, asigna categoría/severidad y anexa evidencia (sin secretos). El estado evoluciona de nuevo a asignado, en curso, resuelto y cerrado; un caso grave se escala con la plantilla de N2. La automatización es mejora opcional. (GLPI Project, s. f.; Unidades Tecnológicas de Santander, 2026)

Brecha respecto a la rúbrica

No se dispone de capturas propias de entidad/profiles, categorías/SLA, envío SMTP, ticket creado, 20 activos en GLPI, exportación de seis tickets ni ensayo backup/restore. Esas actividades no pueden marcarse como terminadas aunque se cuente con matrices y manuales externos a GLPI.

Criterios de comprobación

La verificación definitiva requiere: URL y certificado de la instancia propia, usuario administrativo con permisos correctos, configuración de módulos, prueba de correo de notificación, ticket reproducible con ID real, base de conocimiento publicada y restauración sobre instancia de ensayo.

Tabla 10

Integración operativa y brecha de evidencia

Evidencia	Mínimo técnico a registrar
Ticket	ID, hora, solicitante ficticio, origen, prioridad, estado, resolución
Correo	Cabeceras y cuerpo de notificación sin datos reales
Inventario	20 identificadores que concuerden con Anexo A
Restauración	Backup íntegro, copia restaurada, test de lectura y acta

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Ngfw

Requisitos y dimensionamiento del perímetro

La seguridad de PagoClaro requiere inspección con IPS/antimalware, control de aplicaciones, filtrado DNS/URL, políticas de red, túnel IPsec sede–VPC y exportación a Wazuh. Se adopta 300 Mbps de enlace simétrico como supuesto: aplicando margen del 30 %, el objetivo mínimo es 390 Mbps de protección con servicios activos. Esta cifra no procede de una medición de ISP. (Sierra Pérez, 2026g)

Servicios y continuidad

Los 20 equipos se conectan en una sede con operación híbrida; una API de pagos expuesta en IaaS no debe recibir tráfico directo a base de datos desde estaciones. La política exige VPN segura, MFA para administradores, reglas por origen/destino/aplicación y registros auditables. HA queda como opción futura, no incluida en el ensayo. (Sierra Pérez, 2026d)

Criterios de evaluación

La selección debe examinar calidad de detección, throughput bajo inspección, comportamiento TLS, TCO de 36 meses, integración syslog, soporte en Colombia y facilidad de administración. El precio público no sustituye oferta local que discrimine impuestos, instalación, licencias y SLA de reemplazo.

Tabla 11

Requisitos y dimensionamiento del perímetro

Requisito	Umbral / tratamiento
Equipo protegido	20 endpoints + dispositivos de red
Enlace hipotético	300 Mbps simétricos + 30 % = 390 Mbps
VPN	IPsec sede-nube y acceso privilegiado con MFA
Registro	VPN, IPS, AV, bloqueos, administración → Wazuh
Soporte	Licencias/firmas y soporte durante 36 meses

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Comparativa técnica y decisión documentada

La Fase 5 dejó nueve PDFs diferenciados con características de FortiGate 80F, Palo Alto PA-440 y Sophos XGS 138. El score ponderado académico ubica Fortinet primero con 4,65/5, Sophos segundo con 4,50/5 y Palo Alto con 3,95/5. Los valores reflejan el modelo de evaluación, no prueba empírica de desempeño en la red C05. (Sierra Pérez, 2026g)

Elección técnica

Fortinet FG-80F-BDL-950-36 con UTP/FortiCare por tres años se prefirió por capacidad de protección, VPN, salida de registros y menor precio público publicado entre las alternativas. La ficha del modelo muestra servicios de red y protección con inspección profunda. La cifra de rendimiento se interpreta según los parámetros de ensayo del fabricante. (Fortinet, s. f.)

Comparabilidad y cautelas

Los valores de Palo Alto/Sophos están convertidos a COP desde catálogos externos y pueden tener condiciones distintas de paquete, impuestos, divisa, soporte o mercado. No son equivalentes a tres cotizaciones comerciales vinculantes para Colombia; el plazo de entrega, alcance de implementación y renovación deben quedar aprobados antes de compra. (Sierra Pérez, 2026g)

Tabla 12

Comparativa técnica y decisión documentada

Alternativa	Referencia COP	Score	Lectura
FortiGate 80F	$10.149.000	4,65/5	Preferida académicamente
PA-440	$18.935.104	3,95/5	Mayor subtotal de referencia
Sophos XGS 138	$18.072.283	4,50/5	Buen rendimiento, costo superior

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Nota de evidencia. Los importes referenciales de la Fase 5 no incluyen automáticamente costos integrales de importación y puesta en marcha.

TCO, riesgo del proveedor y decisión de despliegue

El FortiGate 80F se integró al presupuesto empresarial de Fase 7 con COP 10.149.000 publicados y escenario impositivo adicional de 19 %, llevando la línea de adquisición a COP 12.077.310. En el modelo se trata como desembolso inicial que incluye suscripción de 36 meses; no se duplica esta misma licencia en OPEX mensual. (Sierra Pérez, 2026g; Sierra Pérez, 2026i)

No atribuir cotizaciones

Las fichas comerciales publicadas contienen precios de productos y especificaciones, mientras la rúbrica demanda tres cotizaciones reales con proveedor/contacto, fecha y vigencia. Su recepción no consta en los materiales propios, así que la comparación satisface análisis académico pero no acredita contratación.

Plan técnico posterior a compra

Antes de producción: validación de SKU/garantía, respaldo de configuración, reglas de política, IPsec sede–VPC, autenticación MFA, exportación syslog y prueba de alertas en Wazuh. Después: revisión de logs falsos positivos, versiones de firmware, prueba de desconexión y estrategia HA cuando el riesgo de disponibilidad lo exija.

Dependencias críticas

La inspección SSL/TLS requiere análisis de privacidad y compatibilidad con servicios de pago; descifrar indiscriminadamente puede afectar certificados o exposición de datos. Las excepciones deben justificarse por aplicación y mantenerse bajo cambio controlado.

Tabla 13

TCO, riesgo del proveedor y decisión de despliegue

Decisión	Condición de aceptación
Compra	Oferta formal, renovación, IVA, soporte y garantía
Tráfico	Reglas aprobadas, no acceso directo a BD
Observabilidad	Log VPN/IPS/AV decodificado y alerta reproducible
Reversión	Backup configuración y plan de rollback probado

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Procesos del soc n1

Roles, turnos y responsabilidad funcional

El manual del SOC N1 C05 contiene responsables de monitoreo, validación, documentación, escalamiento y respuesta. N1 realiza filtrado de ruido y acciones reversibles expresamente aprobadas; N2 profundiza en investigación, alcance y contención avanzada; TI ejecuta cambios operativos en infraestructura bajo aprobación del líder. (Sierra Pérez, 2026h)

Turnos y cobertura real

El diseño ideal prevé solapamiento de dos jornadas, pero el presupuesto de Fase 7 imputa dos analistas a media jornada equivalente cada uno más guardia rotativa. Esa asignación no garantiza presencia de dos turnos completos de ocho horas y obliga a ajustar SLA/cobertura antes de producción. (Sierra Pérez, 2026h; Sierra Pérez, 2026i)

Segregación RACI

Gerencia aprueba gastos y paso a producción; Líder SOC aprueba arquitectura y operación; TI despliega; N1 ejecuta triage; N2 investiga incidentes críticos; integradores colaboran sin autorizar unilateralmente cambios. La matriz asigna un responsable de aprobación (A) por cada actividad. (Sierra Pérez, 2026i)

Tabla 14

Roles, turnos y responsabilidad funcional

Rol	Permiso ordinario	Restricción clave
N1	Validar, clasificar, preservar y escalar	No borrar evidencia ni cambiar privilegios
N2	Investigar y dirigir contención	Requiere autorización de cambios críticos
TI	Operar sistemas y agentes	No modificar ámbito sin autorización
Líder SOC	Priorizar y aprobar cambios técnicos	Preserva trazabilidad y aprobación
Gerencia	Decidir presupuesto/continuidad	No sustituye análisis técnico

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Matriz de severidad y secuencia de triage

Severidad combina activo crítico, veracidad de la alerta, exposición, amenaza a datos financieros y condición de contención. El triage no comienza por ejecutar bloqueos: inicia confirmando fuente, identidad de host, hora, dispositivo, riesgo y señales correlacionadas. (Sierra Pérez, 2026h)

Flujo de siete decisiones

1) Recibir alerta y registrar hora. 2) Verificar integridad de la fuente e ID. 3) Identificar activo/usuario. 4) Contrastar indicador con historial y cambios. 5) Determinar verdadero positivo, actividad benigna o falso positivo. 6) Calificar severidad y aplicar acciones autorizadas. 7) Documentar, cerrar o escalar con evidencia. El resultado debe ser auditable y reproducible.

Matriz para decisiones

Crítica: afectación real o probable de datos financieros, cuenta privilegiada activa sin aprobación o interrupción de API; Alta: intento creíble con control parcial; Media: evento aislado sin impacto corroborado; Baja: ruido o actividad autorizada. Una alerta de «nivel 12» en Wazuh no equivale automáticamente a severidad empresarial «Crítica».

Tabla 15

Matriz de severidad y secuencia de triage

Severidad	Criterio de ejemplo	Primera acción
Crítica	Transacción/BD comprometida, privilegio activo	Escalar de inmediato, preservar evidencia
Alta	Ejecución o alteración crítica sin causa	Validar N2, controlar exposición
Media	Fallos repetidos sin explotación	Correlacionar y seguir investigación
Baja	Prueba autorizada o cambio esperado	Registrar y cerrar justificadamente

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Catálogo de nueve playbooks PB-01 a PB-09

La fase operativa aportó nueve playbooks adaptados a PagoClaro: autenticación, malware EDR, FIM, VPN, USB, phishing, puertos, privilegios y vulnerabilidad crítica. Cada uno contiene disparadores, triage, límites de contención, evidencia, escalamiento y criterios de cierre. Los procedimientos existen como PDF; su publicación en GLPI no está acreditada. (Sierra Pérez, 2026h)

Control de calidad

Cada playbook debe incluir rutas de evidencias, versión de reglas, revisores y responsables. No se autoriza ejecución de comandos disruptivos sobre la API ni la base de datos sin decisión del dueño del servicio.

Tabla 16

Catálogo de nueve playbooks PB-01 a PB-09

ID	Tipo de alerta	Fuente objetivo	Decisión N1
PB-01	Fuerza bruta SSH/RDP	Wazuh autenticación	Verificar patrón, bloquear solo autorizado
PB-02	Malware detectado por EDR	Kaspersky → Windows/Wazuh	Corroborar bloqueo, alcance, escalar
PB-03	FIM archivos críticos	Wazuh syscheck	Contrastar cambio aprobado / sospechoso
PB-04	VPN login anómalo	NGFW/syslog	Verificar origen, MFA, usuario
PB-05	USB no autorizado	EDR/logs dispositivo	Registrar conexión y políticas
PB-06	Phishing reportado	Usuario/correo	Preservar mensajes, IOC y destino
PB-07	Escaneo de puertos	NGFW/Wazuh	Determinar activos y origen
PB-08	Cuenta privilegiada nueva	Wazuh/DB	Validar autorización, N2 inmediato
PB-09	Vulnerabilidad crítica	CVE/SCA	Priorizar activo y compensaciones

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

SLA, indicadores y registro de incidentes

El manual propone objetivos por prioridad que deben aterrizarse al horario realmente financiado. El diseño de la rúbrica fija para P1 un reconocimiento de 15 minutos y resolución o contención a cuatro horas. Los relojes deberán contar tiempo según calendario definido y el OLA reconocer las obligaciones N1/N2. (GLPI Project, s. f.; Sierra Pérez, 2026h; Unidades Tecnológicas de Santander, 2026)

Medición

KPI fundamentales: MTTD, MTTA, MTTR, porcentaje de alertas triadas, falsos positivos, escalamiento oportuno, cobertura de agentes, cumplimiento SLA, antigüedad de tickets y calidad de evidencia. Los valores base no se inventan: sin muestra de tickets reales y sello de tiempo de ingestión no es correcto publicar un promedio medido.

Tickets exigidos y ejecutados

La rúbrica pide seis tickets con triage completo y origen real para al menos tres. Los documentos propios contienen prueba FIM y EICAR, pero no exportaciones certificadas de seis tickets GLPI. Por ello el Anexo C es un formato de ticket ilustrativo, no un ticket creado en la instancia.

Informe de incidente

El Anexo D describe la prueba EICAR del 21/10/2026, evento 302, bloqueos observados y recepción de registro bruto. No identifica ataque real ni pérdida de datos. El nivel de respuesta corresponde a evento controlado de verificación de detección.

Tabla 17

SLA, indicadores y registro de incidentes

KPI	Definición operativa	Fuente prevista
MTTA	Promedio (asignación/reconocimiento – llegada)	Timestamps del ticket
MTTR	Promedio (solución – detección)	Timeline incidente
Cobertura	Activos activos / 20	Wazuh/EDR e inventario
SLA	Tickets en plazo / tickets evaluables	GLPI – configuración real

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Presupuesto y cronograma

Escenario económico: inversión inicial y operación

Para el caso C05 se modeló un SOC incremental con CAPEX de COP 48.223.427 y OPEX de COP 4.503.673 mensuales. Los topes definidos son COP 70 millones y COP 5 millones, respectivamente. El escenario cabe en ambos límites, condicionado al tamaño de servicio, consumo de nube, vigencia de precios y cargas laborales. (Sierra Pérez, 2026i)

Composición del CAPEX

Equipo NGFW con tres años de licencias; servidor Dell R350; switch 24 puertos; dos puntos Wi-Fi; diez llaves MFA; 60 horas de implementación y 12 horas de formación. Se añade 10 % de contingencia. Kaspersky se considera cargo mensual y GLPI instancia en nube.

No duplicar costos

La licencia FortiGate a 36 meses se paga al inicio en el modelo de caja; no se carga otra vez como OPEX recurrente. Es una decisión de presentación académica y no pretende dictar la clasificación contable. El consumo de API productiva y una operación SOC 24x7 completa no se presupuestan. (Sierra Pérez, 2026i)

Tabla 18

Escenario económico: inversión inicial y operación

Métrica	C05	Tope	Resultado
CAPEX inicial	$48.223.427	$70.000.000	Holgura $21.776.573
OPEX mensual	$4.503.673	$5.000.000	Holgura $496.327
OPEX 36 meses	$162.132.245	No fijado	Proyección
TCO 36 meses	$210.355.672	No fijado	CAPEX + OPEX

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Fuentes, sensibilidad y sostenibilidad 36 meses

El presupuesto de Fase 7 detalla fuentes para firewall, servidor, switch, AP, YubiKey y servicios cloud, junto con supuestos de dedicación, respaldo, DNS, horas profesionales y licenciamiento EDR. La TRM de referencia fue COP 3.163,76 por USD (21/10/2026). Las partidas convertidas mantienen esa tasa como supuesto constante, no como promesa comercial. (Sierra Pérez, 2026i)

Cálculo y desviaciones

TCO = CAPEX + (36 × OPEX mensual). El total COP 210.355.672 proviene de componentes no redondeados; multiplicar el OPEX mensual mostrado por 36 produce una diferencia de COP 17 por redondeo. Se excluyen inflación, descuento de flujos, costos de incidentes y nuevas cargas. Las estimaciones EDR para veinte unidades, N2 externo y nómina N1 son hipótesis académicas que deben sustituirse por ofertas. (Sierra Pérez, 2026i)

Riesgo operativo decisivo

Si se reemplaza el servicio compartido de analistas por una segunda jornada de COP 2.700.000 mensuales, el OPEX aproximado sube a COP 7.203.673, excediendo el límite en COP 2.203.673. Se recomienda negociar MSSP parcial o rediseñar horas y SLA, no asumir cobertura 24/7 a precio insuficiente.

Tabla 19

Fuentes, sensibilidad y sostenibilidad 36 meses

Variable sensible	Impacto que debe probarse
TRM +10 %	Aumento de VM, backups y WAF tarifados USD
Licencia EDR	Cotización 20 puestos vs benchmark 50–99 puestos
Capacidad N1	Disponibilidad, turnos, horas extras y retén
Cuota nube	Acceso, tráfico, backup y retención
HA/continuidad	Segundo NGFW y redundancia SIEM fuera de estimación

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Plan de ocho semanas, hitos y RACI

El cronograma de la Fase 7 propone ejecución del 26/10/2026 al 20/12/2026. Es un plan futuro de puesta en marcha empresarial, diferente de las pruebas académicas de octubre. Se documentaron hitos por semana, una ruta crítica de cotización/NGFW y responsables con una sola A por actividad. (Sierra Pérez, 2026i)

Secuencia general

S1: alcance y autorización; S2: arquitectura/Wazuh base; S3: agentes y FIM/SCA; S4: EDR piloto y correlación; S5: cobertura de veinte equipos y GLPI; S6: NGFW/VPN/WAF; S7: manuales, incidentes y validación; S8: aceptación, transferencia y controles posteriores. No se atribuye ejecución futura a la fecha de corte.

Estado del parcial

Hay material de alcance/arquitectura, evidencias Wazuh y detección EICAR; NGFW, manuales, presupuesto y RACI están documentados. Faltan pruebas de una instancia GLPI propia, exportación de seis tickets, tres cotizaciones emitidas por proveedor y despliegue efectivo de veinte equipos. (Sierra Pérez, 2026i)

Gobierno de cambios

El líder SOC aprueba reglas técnicas; TI administra infraestructura; N2 aprueba tratamiento de alto impacto; Gerencia aprueba costos y paso a producción. Ninguna actividad se considera cerrada si su responsable no aporta prueba de aceptación.

Tabla 20

Plan de ocho semanas, hitos y RACI

Hito	Condición de aceptación
Semana 2	Wazuh disponible, agentes y arquitectura revisados
Semana 4	FIM, EDR y EICAR trazables
Semana 5	20 agentes y GLPI con backup/restore
Semana 6	VPN sede–VPC + syslog perimetral
Semana 8	Acta, inventario, SLA, RACI y riesgos residuales

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Conclusiones

Resultados demostrados y aporte técnico

El ejercicio permite diseñar un SOC Nivel 1 proporcional a una fintech de veinte equipos y servicios transaccionales. La unión de inventario, matriz de riesgos, arquitectura y manual operativo proporciona una base reproducible para clasificar eventos por criticidad y asignar responsables. El mayor valor comprobado está en las pruebas SIEM/EDR sobre endpoints propios. (Sierra Pérez, 2026b; Sierra Pérez, 2026c; Sierra Pérez, 2026e; Sierra Pérez, 2026f)

Logros sustentados

Se cuenta con pruebas de cambio FIM, capturas SCA/vulnerabilidades, reglas locales propuestas y actividad del manager Wazuh. La prueba EICAR fue bloqueada por Kaspersky, registrada por Windows EventChannel y recibida en Wazuh. Se documentó la selección económica del FortiGate 80F y el TCO de operación incremental. (Sierra Pérez, 2026e; Sierra Pérez, 2026f; Sierra Pérez, 2026g; Sierra Pérez, 2026i)

Aprendizajes de validación

El registro bruto en un archivo no implica correlación de alerta personalizada. Una licencia trial con un equipo conectado no acredita despliegue a veinte endpoints. Un precio publicado no equivale a cotización formal y un cronograma no equivale a ejecución. Estas separaciones son centrales para la ética profesional del SOC.

Marco de mejora continua

El sistema deberá revisar cobertura, falsos positivos, tiempo de triage, retención, pruebas de restauración y cambios de reglas. Los KPI se usarán solo después de registrar series de tickets reproducibles y una línea base temporal.

Tabla 21

Resultados demostrados y aporte técnico

Componente	Resultado al corte
Wazuh / FIM / EDR	Laboratorio con pruebas, cobertura parcial
Evento EICAR	Bloqueo y telemetría observada
NGFW	Selección documental, no instalado
GLPI	Arquitectura de proceso definida, sin ejecución propia acreditada
Procesos y presupuesto	Manual, playbooks y TCO documentados

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Limitaciones, riesgos residuales y trabajo futuro

La documentación no debería utilizarse como aceptación de un SOC en producción. Persisten brechas de datos observados, cobertura, licencias, restauración y verificación de contención. Un sistema financiero real necesita acuerdos operativos, respuesta a incidentes probada y una estrategia de continuidad independiente del trabajo académico. (National Institute of Standards and Technology, 2024; PCI Security Standards Council, 2024)

Prioridad 1: reproducibilidad

Confirmar Ubuntu-Agent en línea; verificar la regla 100510 con un evento decodificado correcto y comprobar rule.id en alerts.json. Registrar correlación de fuente, hora, hash y resultado de respuesta. Evitar duplicados y no elevar automáticamente a crítico cada EICAR.

Prioridad 2: gestión ITSM

Implementar instancia GLPI propia con HTTPS, perfiles, categorías, SLA/OLA, 20 activos, 12 artículos, correo y backup/restore. Crear seis tickets y demostrar que tres corresponden a alertas reales de laboratorio con trazabilidad temporal completa.

Prioridad 3: producto empresarial

Obtener tres cotizaciones con identificación y vigencia; verificar compatibilidad Kaspersky macOS y Ubuntu; dimensionar verdadero EPS, almacenamiento y residencia de datos; probar VPN/NGFW/WAF en entorno aislado. Revisar suficiencia presupuestal para turnos y retén de seguridad.

Tabla 22

Limitaciones, riesgos residuales y trabajo futuro

Riesgo residual	**Tratamiento prioritario**
Punto único Wazuh/NGFW	Continuidad, respaldo y HA por costo/criticidad
Cobertura de solo piloto	Plan de 20 agentes y validación individual
Respuesta no homologada	Simulación de incidentes, autorización y ensayos
Diferencia entre plan y evidencia	Checklist firmado y trazabilidad de capturas

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Referencias

Amazon Web Services. (s. f.). *Precios de Amazon Lightsail y AWS WAF*. https://aws.amazon.com/es/lightsail/pricing/

Congreso de la República de Colombia. (2008). *Ley 1266 de 2008, disposiciones generales del habeas data.* https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=34488

Congreso de la República de Colombia. (2009). *Ley 1273 de 2009, protección de la información y los datos.* https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=34492

Congreso de la República de Colombia. (2012). *Ley 1581 de 2012, disposiciones generales para la protección de datos personales.* https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981

Fortinet. (s. f.). *FortiGate/FortiWiFi 80F series: Data sheet.* https://www.fortinet.com/content/dam/fortinet/assets/data-sheets/fortigate-fortiwifi-80f-series.pdf

GLPI Project. (s. f.). *Documentación de GLPI: Entidades, categorías y niveles de servicio.* https://help.glpi-project.org/documentation/

Kaspersky. (s. f.). *Kaspersky Next EDR Optimum.* https://latam.kaspersky.com/next-edr-optimum

National Institute of Standards and Technology. (2024). *The NIST cybersecurity framework (CSF) 2.0 (NIST CSWP 29).* https://doi.org/10.6028/NIST.CSWP.29

PCI Security Standards Council. (2024). *Payment Card Industry Data Security Standard: Requirements and testing procedures (versión 4.0.1).* https://www.pcisecuritystandards.org/document_library/

Sierra Pérez, N. E. (2026a). *Autorización y reglas de compromiso SOC C05 [Documento académico no publicado]*.

Sierra Pérez, N. E. (2026b). *Inventario de activos C05 [Hoja de cálculo no publicada]*.

Sierra Pérez, N. E. (2026c). *Matriz de riesgos C05 [Hoja de cálculo no publicada]*.

Sierra Pérez, N. E. (2026d). *Arquitectura SOC PagoClaro C05 [Diagrama técnico no publicado]*.

Sierra Pérez, N. E. (2026e). *Pruebas Wazuh y plan de despliegue de agentes C05 [Capturas y material de laboratorio no publicados]*.

Sierra Pérez, N. E. (2026f). *Pruebas Kaspersky EDR, evento EICAR y recolección Wazuh C05 [Capturas de laboratorio no publicadas]*.

Sierra Pérez, N. E. (2026g). *Evaluación comparativa NGFW C05 [Documentos técnicos de la fase 5 no publicados]*.

Sierra Pérez, N. E. (2026h). *Manual SOC N1, nueve playbooks e informe de incidente EICAR [Documentos internos no publicados]*.

Sierra Pérez, N. E. (2026i). *Presupuesto, cronograma y matriz RACI C05 [Documentos internos no publicados]*.

Unidades Tecnológicas de Santander. (2026). *Parcial práctico de ética del hacking: Implementación de un SOC nivel 1 [Guía académica]*.

Wazuh. (s. f.). *User manual: Wazuh components, FIM, SCA and vulnerability detection.* https://documentation.wazuh.com/current/user-manual/

Apéndice A

Inventario completo, activos A-01 a A-10

Fuente: Inventario_Activos_C05(1).xlsx. La columna «Agentes» es estado de planificación, no instalación acreditada. El total obligatorio del caso comprende 20 computadores; los dispositivos de red y servicios adicionales se muestran por separado.

Tabla A1

Inventario completo, activos A-01 a A-10

ID	Hostname	SO	Función	VLAN	W/K/G
A-01	PC-C05-01	Windows 11	Operaciones	10	Pr/Pr/Pr
A-02	PC-C05-02	Windows 11	Operaciones	10	Pr/Pr/Pr
A-03	PC-C05-03	Windows 11	Operaciones	10	Pr/Pr/Pr
A-04	PC-C05-04	Windows 11	Operaciones	10	Pr/Pr/Pr
A-05	PC-C05-05	Windows 11	Soporte	10	Pr/Pr/Pr
A-06	PC-C05-06	Windows 11	Soporte	10	Pr/Pr/Pr
A-07	PC-C05-07	Windows 11	Soporte	10	Pr/Pr/Pr
A-08	PC-C05-08	Windows 11	Soporte	10	Pr/Pr/Pr
A-09	LAP-C05-01	Windows 11	Gerencia	10	Pr/Pr/Pr
A-10	LAP-C05-02	Windows 11	Gerencia	10	Pr/Pr/Pr

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Inventario completo, activos A-11 a A-20

La validación de agentes macOS y Ubuntu y la alta individual de cada activo a GLPI dependen de pruebas pendientes. La criticidad original se conserva en el archivo de inventario.

Tabla A2

Inventario completo, activos A-11 a A-20

ID	Hostname	SO	Función	VLAN	W/K/G
A-11	LAP-C05-03	Windows 11	Cumplimiento	10	Pr/Pr/Pr
A-12	MAC-C05-01	macOS	Desarrollo	10	Pr/Ve/Pr
A-13	MAC-C05-02	macOS	Desarrollo	10	Pr/Ve/Pr
A-14	MAC-C05-03	macOS	Desarrollo	10	Pr/Ve/Pr
A-15	MAC-C05-04	macOS	Desarrollo	10	Pr/Ve/Pr
A-16	MAC-C05-05	macOS	Desarrollo	10	Pr/Ve/Pr
A-17	SRV-C05-BASTION	Ubuntu Server	Acceso administrativo	30	Pr/Ve/Pr
A-18	SRV-C05-BD	Ubuntu Server	Réplica base de datos	20	Pr/Ve/Pr
A-19	SRV-C05-APP	Ubuntu Server	Aplicación	20	Pr/Ve/Pr
A-20	SRV-C05-BACKUP	Ubuntu Server	Respaldos	20	Pr/Ve/Pr

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Equipos de red y servicios fuera de los 20 puestos

Las siguientes filas se conservaron del inventario aportado. Los servicios cloud forman parte de la superficie de ataque del caso y no se contabilizan como estaciones adicionales.

Tabla A3

Equipos de red y servicios fuera de los 20 puestos

ID	Nombre	Tipo	Función
R-01	NGFW-C05	Firewall	Seguridad perimetral
R-02	SW-C05-01	Switch	Conectividad y VLAN
R-03	AP-C05-01	Access Point	WiFi corporativa
R-04	AP-C05-02	Access Point	WiFi corporativa
S-01	API-C05	Pasarela API	API de pagos
S-02	CORE-C05	Servicio cloud	Núcleo transaccional

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice B

Matriz de riesgos completa – R-01 a R-05

Escalas P e I de 1 a 5. Riesgo = P×I; 1–4 bajo, 5–9 medio, 10–16 alto, 17–25 crítico. Calificaciones previas a validación en producción. (Sierra Pérez, 2026c)

Tabla B1

Matriz de riesgos completa – R-01 a R-05

ID	Riesgo	Activo	P/I	Nivel
R-01	Acceso administrativo anómalo por VPN	SRV-C05-BASTION	4/5	20 (Crítico)
R-02	Modificación no autorizada de archivos de API	SRV-C05-APP	3/5	15 (Alto)
R-03	Creación indebida de cuenta privilegiada	SRV-C05-BD	3/5	15 (Alto)
R-04	Compromiso de API de pagos	API-C05	4/5	20 (Crítico)
R-05	Acceso no autorizado a transacciones	SRV-C05-BD	3/5	15 (Alto)

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Matriz de riesgos completa – R-06 a R-10

Los controles consignados son objetivos SOC; para concluir eficacia deben demostrarse alertas y seguimiento. (Sierra Pérez, 2026c)

Tabla B2

Matriz de riesgos completa – R-06 a R-10

ID	Riesgo	Activo	P/I	Nivel
R-06	Robo de credenciales por phishing	PC-C05-01	4/4	16 (Alto)
R-07	Ransomware en estaciones Windows	PC-C05-02	3/5	15 (Alto)
R-08	Exposición de llaves de cifrado	SRV-C05-APP	3/5	15 (Alto)
R-09	Pérdida de registros de auditoría	SRV-C05-BASTION	3/4	12 (Alto)
R-10	Configuración insegura en servicios cloud	CORE-C05	3/5	15 (Alto)

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice C

Formato de ticket: prueba EICAR documentada (no creado en GLPI)

Registro ilustrativo construido a partir del evento realmente observado. No se asigna ID de ticket GLPI ni se indica envío de notificación. Sirve como formato listo para registrar en la propia instancia tras finalizar Fase 4.

Tabla C1

Formato de ticket: prueba EICAR documentada (no creado en GLPI)

Campo	Contenido sustentado / ejemplo
Título	[Kaspersky] Event 302 – EICAR bloqueado en Chrome
Origen	Kaspersky Endpoint Security / Windows EventChannel
Fecha y hora	21/10/2026 11:34:05, America/Bogota
Activo	NELSON (Windows 11, endpoint de laboratorio)
Categoría	Seguridad > Malware > Prueba controlada
Resumen	Kaspersky identificó EICAR-Test-File y negó descarga
IOC	https://secure.eicar.org/eicar.com.txt
Clasificación	Prueba autorizada de funcionamiento, sin compromiso real
Acciones N1	Corroborar bloqueo, recuperar evento, verificar recepción SIEM
Escalamiento	No requerido para EICAR; escalar si aparecen indicadores de amenaza real
Estado GLPI	Sin ID: no hay evidencia de creación propia del ticket

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice D

Relación del informe de incidente completo

Se adjunta como páginas subsecuentes el archivo «11_Anexo_D_Informe_Incidente_EICAR_C05.pdf», redactado previamente con estructura de doce secciones exigidas: identificación, resumen, detección, cronología, afectados, análisis, respuesta, impacto, recomendaciones, aprendizajes, notificaciones y evidencias. La prueba EICAR y el registro Windows 302 son los datos centrales.

Criterio probatorio

Se verificó bloqueo preventivo del objeto y recolección del registro de Windows. No se afirma compromiso de datos ni disparo comprobado de la regla 100510. No se consigna un número inventado de ticket GLPI.

Anexo externo incorporado

Las páginas que siguen a las secciones A–J integran el informe completo de incidente ya generado en la Fase 6. También se incorporarán los nueve playbooks PDF disponibles.

Apéndice E

NGFW: cuadro de opciones y estado de cotizaciones

La ficha de Fase 5 utiliza precios públicos como referencias de mercado; se requiere documento comercial auténtico de cada proveedor para acreditar el requisito de cotización formal. Las solicitudes preparadas en Fase 5 tampoco equivalen a respuestas recibidas.

Condiciones mínimas

Fecha, NIT/proveedor, contacto, SKU, licencias a 36 meses, impuesto/IVA, instalación, garantía, renovación, vigencia y tiempo de entrega. La valoración comparada es válida solo bajo equivalencia real de alcances.

Tabla E1

NGFW: cuadro de opciones y estado de cotizaciones

Proveedor/alternativa	Precio público COP	Documento formal C05
Datacenter360 / FortiGate 80F	$10.149.000	No acreditado
Cátalogo externo / PA-440	$18.935.104	No acreditado
Catálogo externo / Sophos XGS 138	$18.072.283	No acreditado

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice F

Playbooks PB-01 a PB-09 y anexión completa

El manual operativo de Fase 6 define nueve procedimientos que corresponden a eventos relevantes en PagoClaro. Los originales PDF se incorporan íntegros al final del presente documento, con su contenido de disparadores, severidades, triage, contención y escalamiento.

Tabla F1

Playbooks PB-01 a PB-09 y anexión completa

Playbook	Amenaza / objetivo
PB-01	Fuerza bruta SSH/RDP
PB-02	Malware detectado por Kaspersky EDR
PB-03	Cambio FIM de archivos críticos
PB-04	VPN administrativa inusual
PB-05	Dispositivo USB no autorizado
PB-06	Phishing reportado
PB-07	Escaneo de puertos/reconocimiento
PB-08	Cuenta privilegiada nueva
PB-09	Vulnerabilidad crítica detectada

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice G

Checklist de entrega según evidencia disponible

Estado al 21/10/2026; «parcial» no debe confundirse con aprobado. Los campos son verificación documental y requieren nueva comprobación en la jornada de sustentación.

Tabla G1

Checklist de entrega según evidencia disponible

Ítem	Estado	Sustento / observación
Fase 0: autorización, inventario, riesgos	Parcial	Documentos; autorización sin firma verificada
Fase 1: arquitectura y flujos	Documentado	PDF y diagramas propios
Fase 2: Wazuh, agentes, detección	Parcial	Evidencias FIM/SCA/alertas, cobertura incompleta
Fase 3: Kaspersky y EICAR	Parcial	Bloqueo, trial y recepción log; regla 100510 no comprobada
Fase 4: GLPI completo	No acreditado	Sin capturas propias y restauración verificada
Fase 5: tres cotizaciones reales	Parcial	Precios públicos y matriz; respuestas no acreditadas
Fase 6: manual, 9 PB, 6 tickets	Parcial	Manual/PB/Anexo D disponibles; 6 tickets no probados
Fase 7: presupuesto, RACI	Documentado	PDF/Excel Fase 7
Fase 8: PDF final	Documentado	Informe generado; video/repositorio sujetos a su entrega

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice H

Autorización y reglas de compromiso – síntesis documental

Documento de base: Autorizacion_y_Reglas_Compromiso_SOC_C05_Actualizada.docx. Corresponde a un texto de autorización académica en preparación y no a una autorización efectiva hasta validación y firma del docente.

Tabla H1

Autorización y reglas de compromiso – síntesis documental

Aspecto	Condición C05
Partes	Organización ficticia PagoClaro / estudiante consultor / docente
Objeto	Diseñar y ensayar SOC N1 en VMs propias
Permitido	FIM, fallos de autenticación de prueba y EICAR
Prohibido	Atacar terceros, divulgar secretos o procesar datos financieros reales
Ventana	Dos semanas propuestas; campo fecha de validación no diligenciado
Desistimiento	Detener ante impacto inesperado y comunicar al docente
Custodia	Pública/interna/confidencial/restringida por clasificación
Firma	Pendiente de validación; no se inventa consentimiento

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice I

Declaración de uso de inteligencia artificial

Se declara de forma expresa el apoyo de ChatGPT/OpenAI para la organización del informe, propuestas de estructura, redacción técnica, resúmenes de configuraciones, tablas e integración de anexos. Las decisiones técnicas, capturas y ejecuciones del laboratorio deben ser comprobadas por el estudiante antes de la entrega.

Compromiso del autor

Este documento requiere revisión del estudiante, confirmación de capturas, edición de hallazgos y capacidad de explicar los controles ante el docente. Firma académica:

_____ Fecha: ____ / ____ / _____

Tabla I1

Declaración de uso de inteligencia artificial

Herramienta	Para qué se usó	Qué se contrastó	Límite del uso
ChatGPT (OpenAI)	Organización de 10 capítulos, síntesis de materiales, formato PDF	Rúbrica, inventario, riesgos, anexos y presupuestos entregados	No genera eventos reales ni valida GLPI
Documentación oficial	Consulta de capacidades y marcos de seguridad	Wazuh, Kaspersky, GLPI, NIST, PCI, Fortinet	No sustituye prueba local

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice J

Glosario de términos técnicos

Las definiciones se ofrecen para uniformar la lectura de los diez capítulos.

Tabla J1

Glosario de términos técnicos

Sigla	Definición aplicada
SOC N1	Monitoreo inicial, clasificación, documentación y escalamiento
SIEM	Correlación de eventos y registros de seguridad
EDR / XDR	Protección, detección e investigación en endpoints y múltiples fuentes
FIM	Monitoreo de integridad de archivos
SCA	Evaluación de postura y configuración de seguridad
NGFW / WAF	Firewall avanzado de red / cortafuegos para aplicaciones web
CVE / IOC	Vulnerabilidad pública / indicador de compromiso
MTTD/MTTA/MTTR	Tiempo medio de detección / reconocimiento / resolución
SLA / OLA	Acuerdo con cliente / acuerdo entre grupos operativos
CAPEX/OPEX/TCO	Inversión / gasto recurrente / costo total
RACI	Responsable, aprobador, consultado, informado
MFA / VPN	Autenticación multifactor / red privada virtual

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Apéndice - Evidencias

Índice fotográfico seleccionado del laboratorio

Las siguientes capturas son materiales aportados por el proyecto C05 y se muestran como evidencia contextual. La fecha/hora y el nombre de host deben corroborarse sobre el archivo fuente; se evita atribuir a estas capturas componentes ajenos al piloto.

Tabla K1

Índice fotográfico seleccionado del laboratorio

Figura	Archivo de evidencia	Qué permite observar
E1	F02_08_Alerta_FIM_PagoClaro.png	Alerta FIM de prueba
E2	F02_09_Evaluacion_SCA.png	Panel SCA
E3	F02_10_Deteccion_Vulnerabilidades.png	Hallazgo CVE
E4	F02_12_Regla_100501.png	Regla local propuesta
E5	F03_14_Detalles_Deteccion_EICAR.png	Detección web/EDR
E6	F03_19_Kaspersky_Evento_EICAR_Windows.png	Windows Event ID 302

Nota. Elaboración académica para el caso C05 a partir de los documentos y registros del laboratorio, salvo que se indique otra fuente.

Captura E1 - FIM y E2 - vulnerabilidades

Pruebas defensivas y consulta de postura registradas en el entorno Wazuh representativo. Las capturas deben interpretarse con su objetivo de laboratorio, no como hallazgos en una infraestructura de PagoClaro en producción.

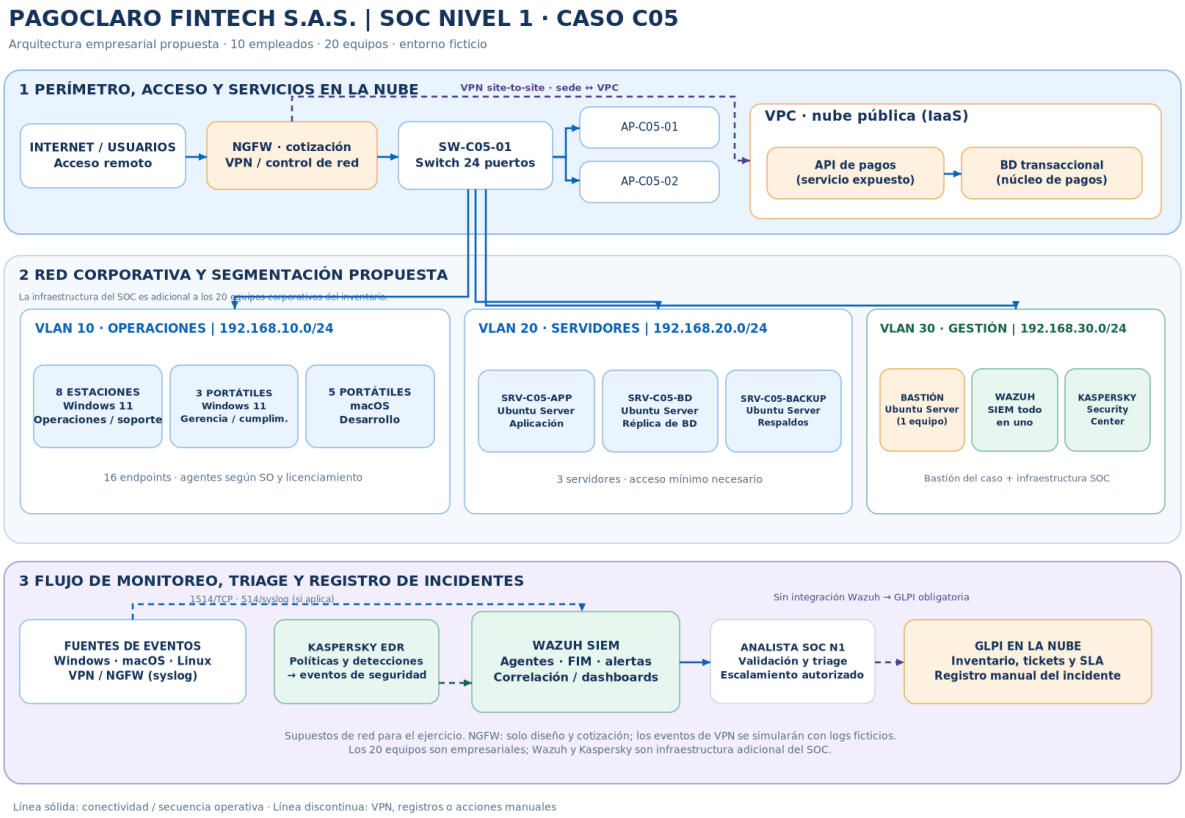
Captura E3 - Kaspersky y E4 - registro de Windows

En el ensayo de archivo EICAR, el navegador recibió bloqueo y el canal EventChannel permitió comprobar el mensaje del proveedor avp. Se trata del único ejemplo de detección EDR probado en el material expuesto, no de un ataque real.

Apéndice K: Evidencias fotográficas del laboratorio

Figura K1

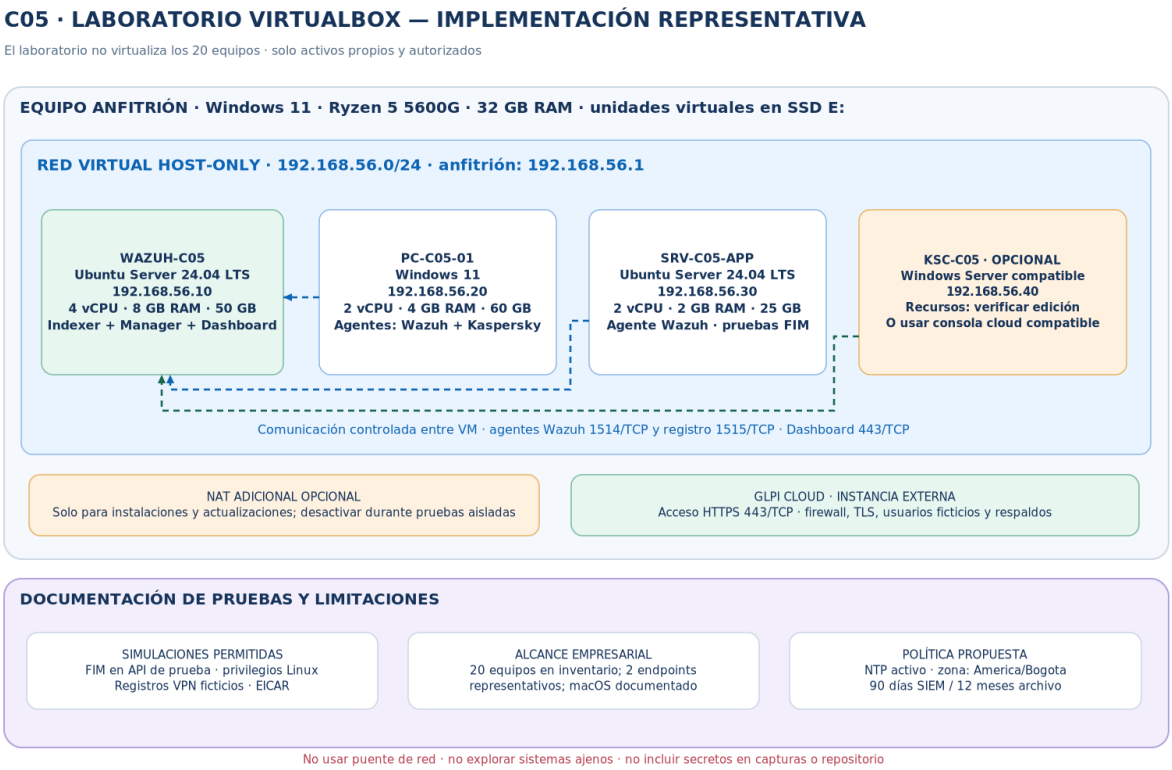
Diagrama de arquitectura empresarial C05 aportado al proyecto; corresponde a diseño, no instalación productiva.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K2

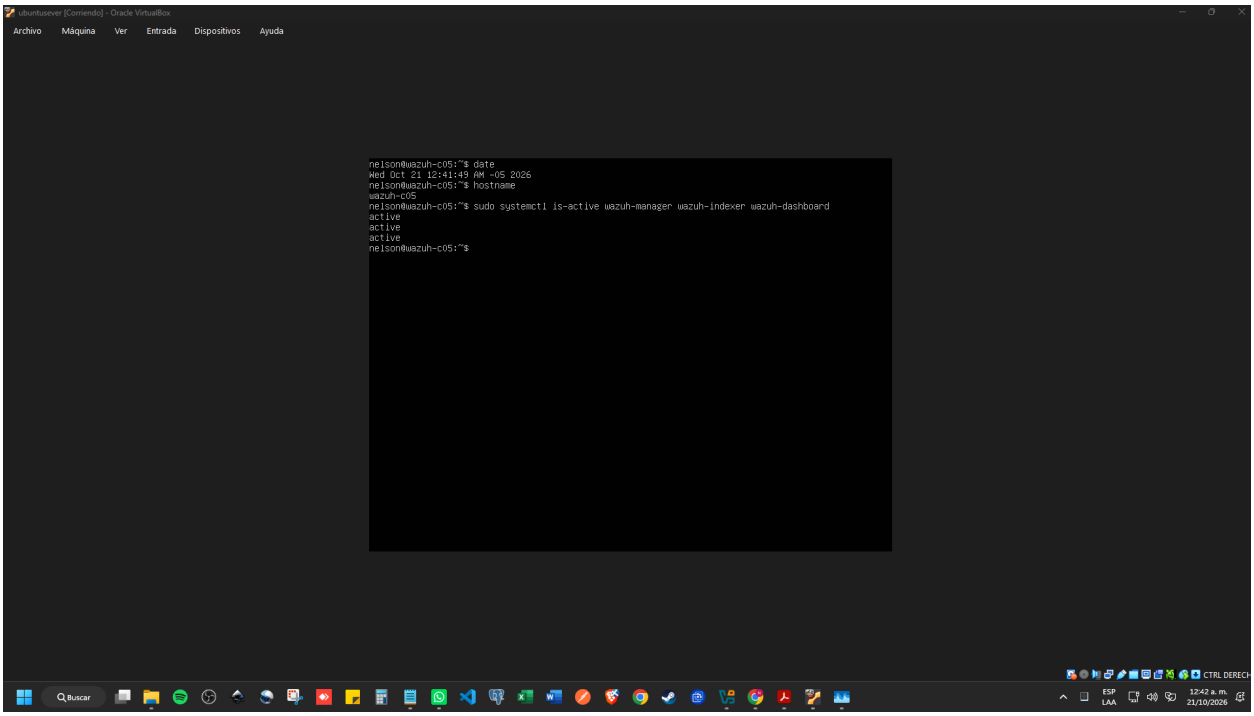
Diseño de laboratorio con Wazuh y endpoints representativos; diagrama suministrado por el estudiante.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K3

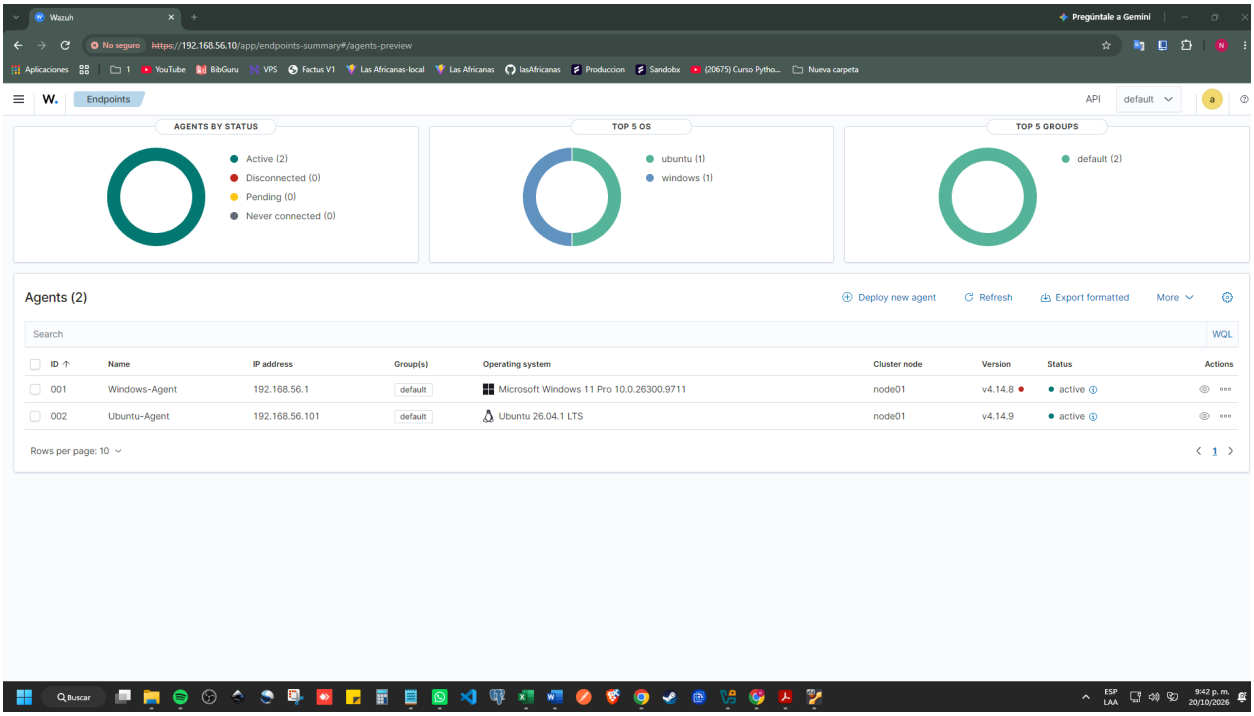
Evidencia aportada de servicios Wazuh del laboratorio. Verificar en vivo el estado actual antes de la sustentación.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K4

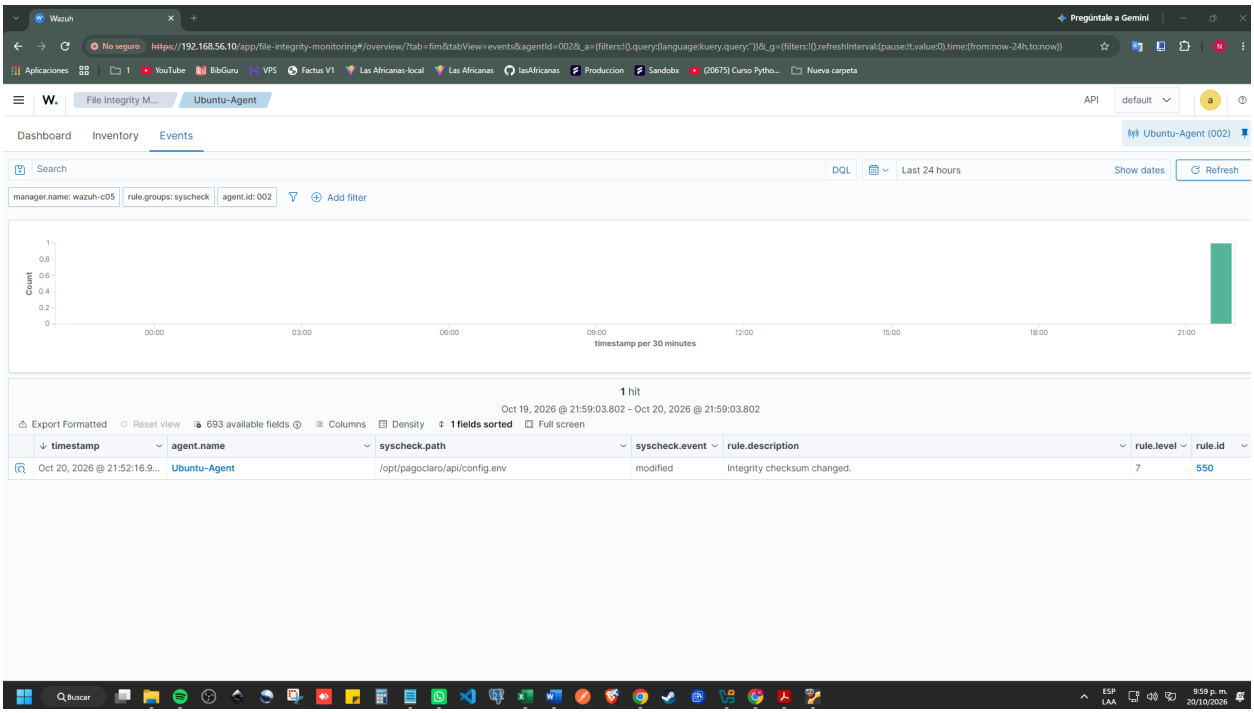
Vista de agentes Windows y Ubuntu; los estados representados corresponden al instante de captura, no a disponibilidad continua.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K5

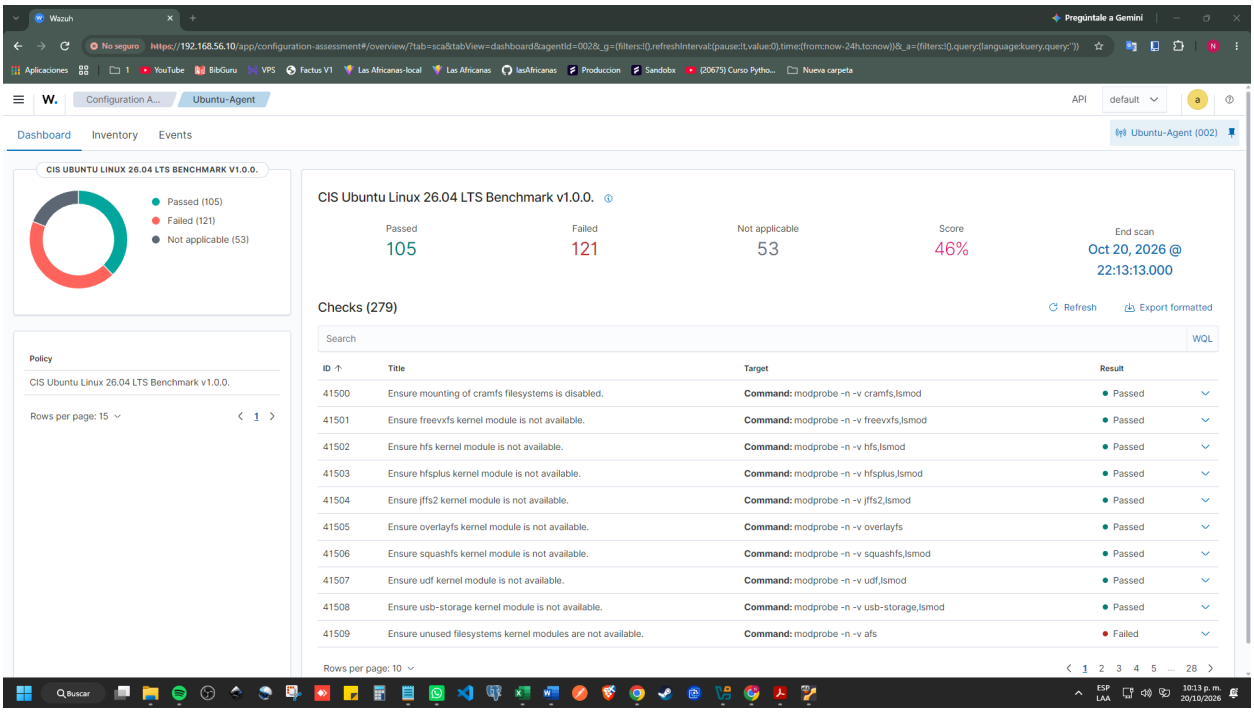
Detección FIM aportada para el caso C05; control asociado al PB-03.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K6

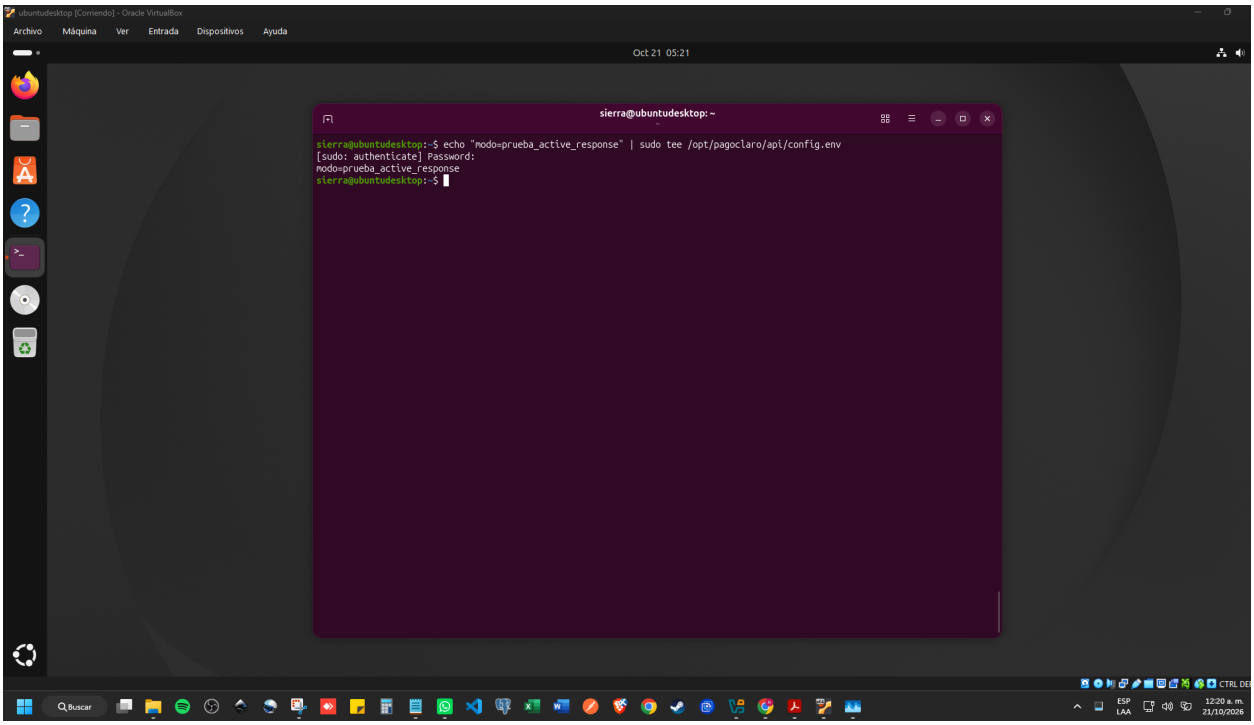
Pantalla de evaluación SCA del laboratorio.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K7

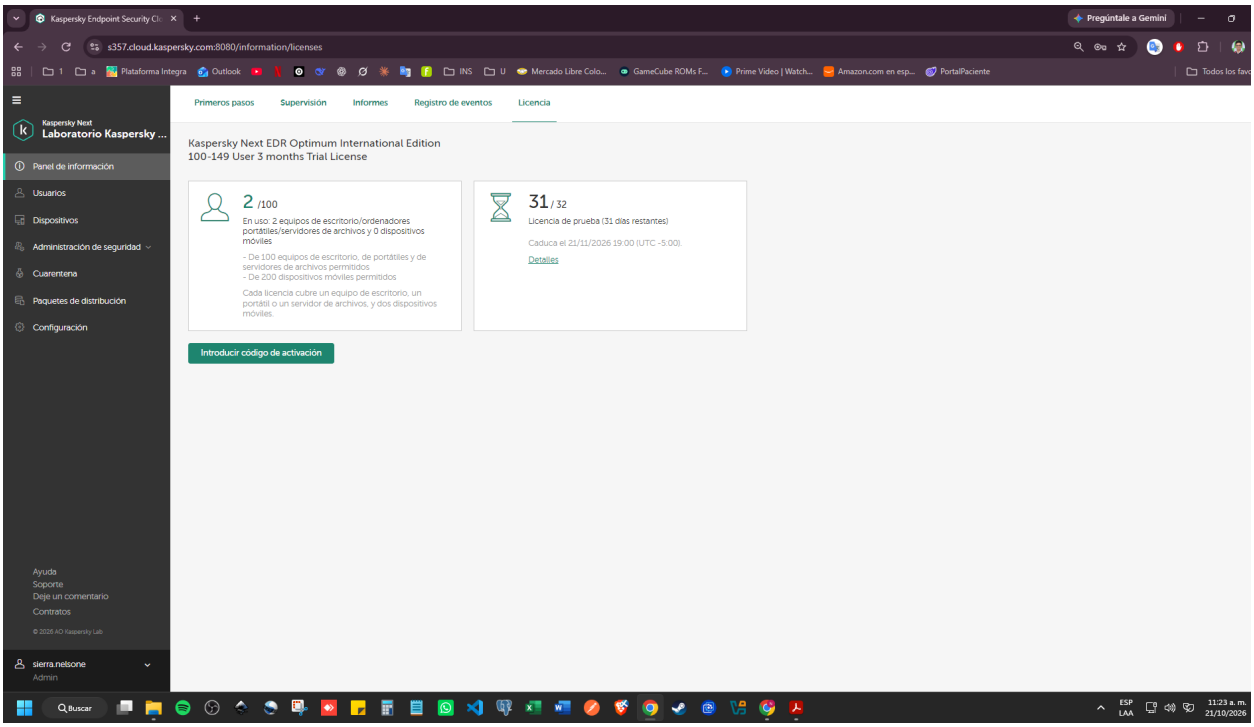
Evidencia seleccionada de prueba controlada de respuesta activa.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K8

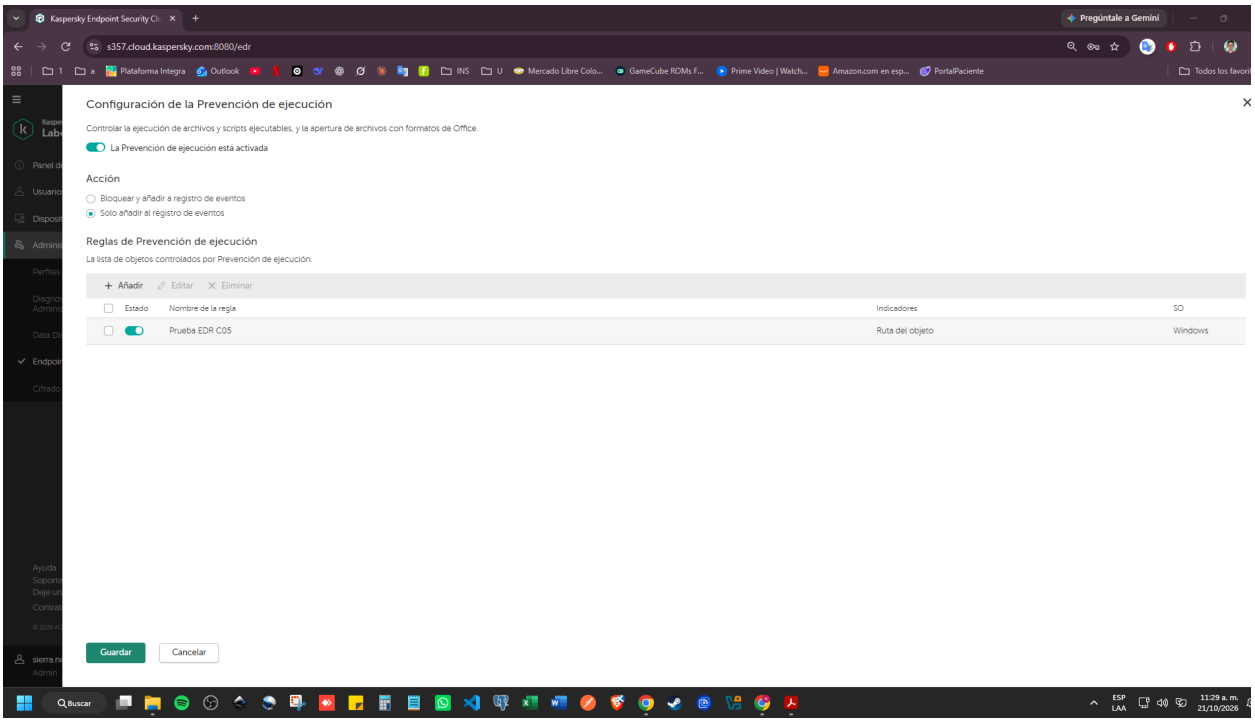
Licencia temporal consultada el 21 de octubre; vencimiento registrado el 21 de noviembre de 2026.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K9

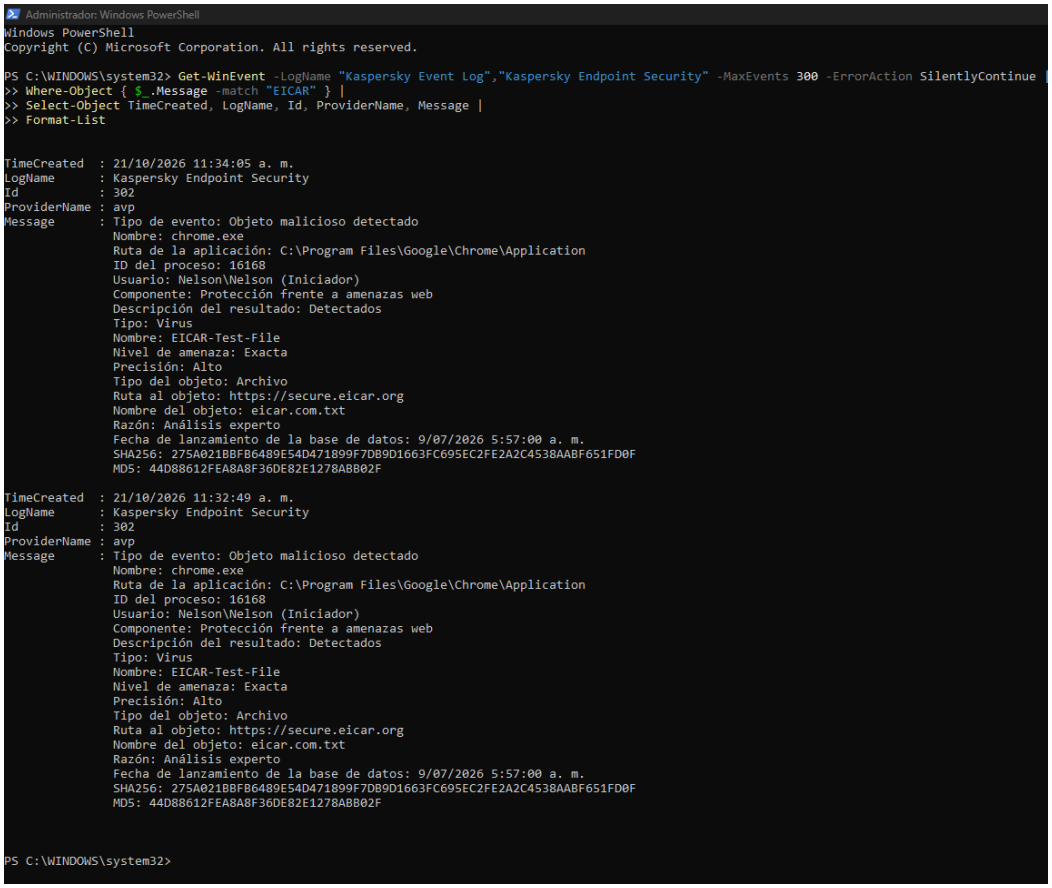
Prevención de ejecución activada en modo registro para ensayo académico.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K10

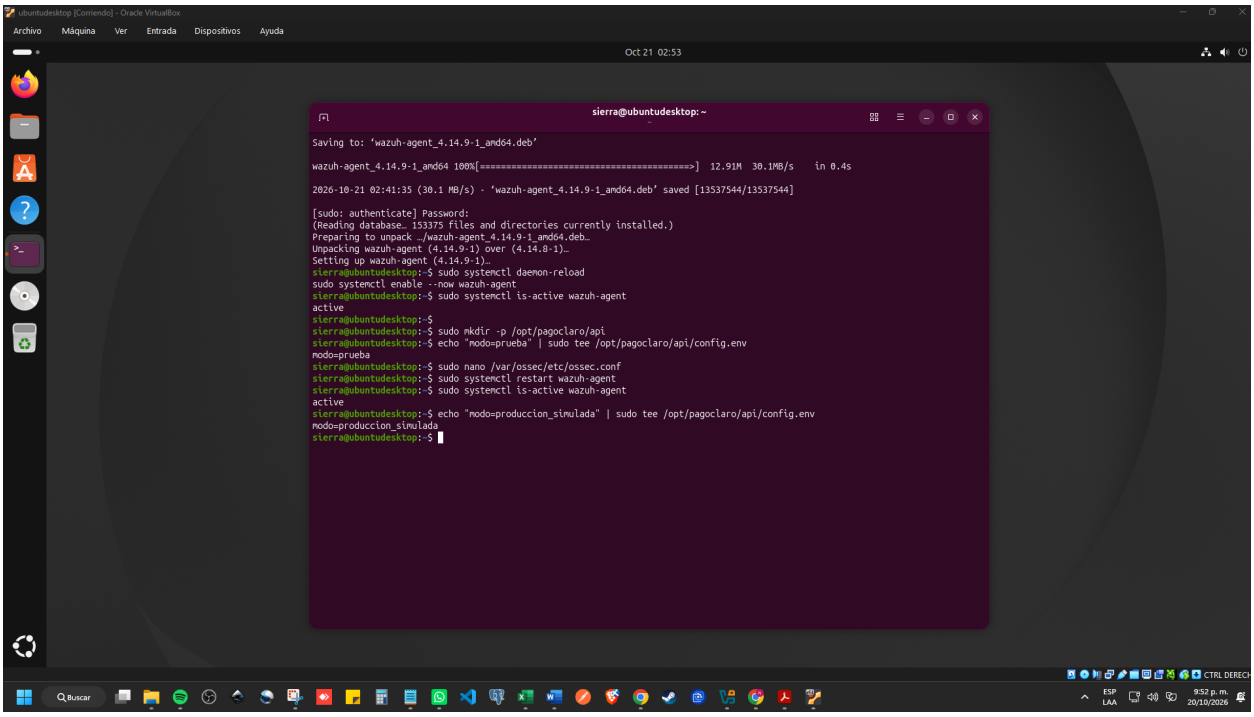
Registro Windows de detección EICAR empleado para el análisis del Anexo D.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K11

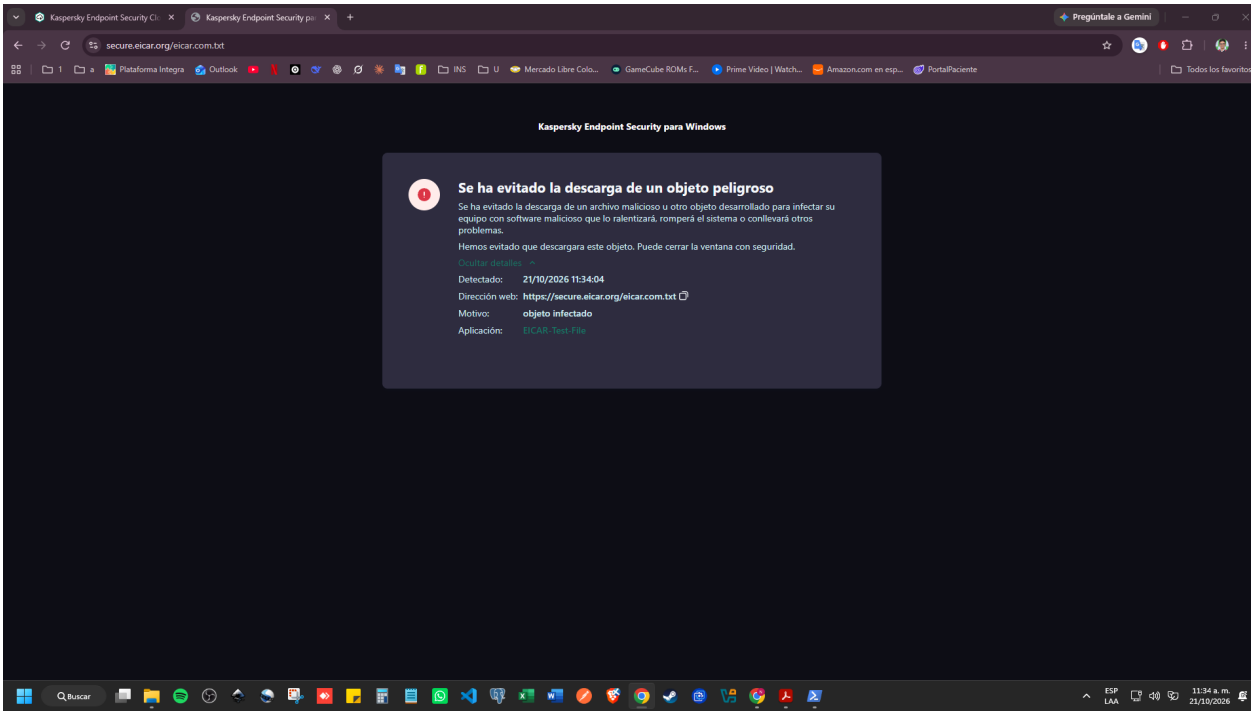
E1. Cambio de archivo de prueba supervisado por Wazuh.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Figura K12

E3. Detección de EICAR y bloqueo de descarga en Kaspersky.



Nota. Captura del laboratorio C05 proporcionada como evidencia documental; representa exclusivamente el estado visible en el momento de su registro.

Apéndice L: Informe de incidente EICAR, Anexo D

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6 Anexo D | Informe de incidente Caso de prueba EICAR controlada, Kaspersky en Windows y recepción de registro en Wazuh

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental INC-C05-20261021-001 | Versión 1.0 | Corte documental: 21/10/2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Naturaleza del caso Evento de laboratorio confirmado: prueba antivirus EICAR bloqueada. EICAR no es malware real. No debe comunicarse como compromiso confirmado de los sistemas transaccionales.

1. Identificación

Campo Valor Número de incidente INC-C05-20261021-001 (asignación documental académica) Fecha y hora de detección 21/10/2026, 11:34:04-11:34:05 (America/Bogota, UTC-5)

Origen Kaspersky Endpoint Security para Windows / Windows Event Log Analista Responsable del laboratorio SOC N1 - Caso C05 Severidad final Media: detección de archivo EICAR y descarga impedida en un único equipo.

Estado técnico observado Descarga bloqueada, detección registrada localmente; evento ingerido en Wazuh. No hay evidencia suficiente de compromiso real. Ámbito Equipo Windows de laboratorio NELSON; no se comprobó afectación al API o BD de

PagoClaro. Uso académico | Laboratorio de ciberseguridad defensiva Anexo D: EICAR C05 • 1 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

2. Resumen ejecutivo

El 21 de octubre de 2026, durante una verificación autorizada, se intentó acceder al archivo de prueba EICAR desde Chrome. Kaspersky impidió la descarga y registró el evento en el equipo. El servicio de Wazuh recibió registros asociados. No se observó ejecución de malware real ni afectación al servicio de pagos. El resultado demuestra bloqueo

local y recolección de telemetría, sin acreditar por sí mismo una correlación personalizada del SIEM.

3. Detección

Fuente primaria: Protección frente a amenazas web de Kaspersky. Evento local: proveedor «avp», canal «Kaspersky Endpoint Security», ID 302, nombre «EICAR-Test-File», proceso chrome.exe. La evidencia mostrada corresponde al bloqueo de la descarga y a dos detecciones locales a las 11:32:49 y 11:34:05. Wazuh recolectó eventos del canal con

Windows EventChannel: la existencia de registros archivados de EICAR se observa en el laboratorio.

4. Línea de tiempo (America/Bogota)

Hora local Evento sustentado Fuente 11:32:48-49 Primer bloqueo y detección del archivo EICAR. Kaspersky: informes /

Windows Event Log 11:34:04 Nueva descarga denegada; Chrome recibe página de bloqueo. Kaspersky: protección web / captura 11:34:05 Evento de detección EICAR, ID 302, canal Kaspersky Endpoint Security. PowerShell / Windows Event

Log Después de la Se identifican registros EICAR presentes en archivo JSON de Wazuh. La hora de Wazuh: archives.json recolección ingestión no fue verificada. (capturas de laboratorio)

En análisis del Se propuso regla personalizada 100510; la captura no acredita activación ni local_rules.xml / pruebas laboratorio disparo de esta regla. mostradas

5. Activos, usuarios y servicios afectados

Host: NELSON (Windows 11 del laboratorio). Usuario observado en registro: Nelson\Nelson. Proceso: chrome.exe. Servicio implicado: navegación web. No se evidenció contacto con servidores de API, bastión, réplica PostgreSQL, VPN ni componentes de producción de PagoClaro. El nombre «Windows-Agent» aparece en el servidor Wazuh como agente

activo. Uso académico | Laboratorio de ciberseguridad defensiva Anexo D: EICAR C05 • 2 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

6. Análisis técnico, causa e indicadores

Elemento Dato / interpretación Nombre de detección EICAR-Test-File; archivo de prueba de antivirus, sin capacidad dañina real. Artefacto eicar.com.txt, URL mostrada: https://secure.eicar.org/eicar.com.txt

Proceso involucrado chrome.exe, ruta de aplicación Chrome en Program Files. Registro Windows Kaspersky Endpoint Security, provider avp, Event ID 302. Integración con Wazuh Lectura del canal «Kaspersky Endpoint Security» con log_format eventchannel. La ingesta en

archives.json se ha observado. Regla personalizada 100510 fue propuesta en pruebas anteriores; no hay confirmación documental suficiente de disparo por ella. Causa probable Prueba manual intencional de validación de protección web durante laboratorio académico.

Indicadores externos Dominio secure.eicar.org reconocido como origen de archivo de prueba; no es un IOC de ataque real. No atribuir a la captura de EICAR el hash de un ejecutable malicioso real: el registro mostrado aporta la firma de prueba. Los valores

hash de EICAR, si se conservan, corresponden únicamente al archivo de demostración.

7. Contención y respuesta ejecutada

Responsable Acción Resultado comprobable Kaspersky (automática) Impedir descarga de objeto clasificado EICAR. Bloqueado / descarga denegada. Analista N1 Consultar informe local y evento Windows; extraer Registro 302 y capturas del módulo web.

evidencia. Analista N1 Comprobar la recolección por Wazuh. Cadena EICAR observada en registros archivados. N2 / TI Aislamiento, restauración o borrado. No consta ejecución; no se atribuye como hecho.

8. Impacto en confidencialidad, integridad y disponibilidad

Dimensión Evaluación técnica Sustento Confidencialidad No hay indicios de pérdida. Archivo de prueba; no se observó lectura de datos financieros. Integridad Sin cambios demostrados. Se interceptó descarga; no se confirmó ejecución.

Disponibilidad Sin indisponibilidad Chrome y servicios de seguridad registraron bloqueo; no afectación demostrada. API. Datos personales Sin afectación confirmada. No se obtuvo evidencia de consulta/exfiltración.

Uso académico | Laboratorio de ciberseguridad defensiva Anexo D: EICAR C05 • 3 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

9. Recomendaciones y responsables

Prioridad Acción Responsable Plazo propuesto Alta Ajustar la regla 100510 a un campo efectivamente decodificado y Responsable SOC + admin Siguiente sesión de

probarla con evento de laboratorio. Wazuh pruebas Media Validar horario, NTP y correlación entre EDR, registro Windows y Analista N1 Siguiente turno SIEM.

Media Comprobar análisis completo de equipo tras el ejercicio y verificar Administrador TI Siguiente ventana actualización de bases. Baja Conservar capturas y archivo de alerta saneado, con integridad y Analista N1 Antes de entrega

hora documentadas. final

10. Lecciones aprendidas

- Funcionó la protección de navegación: Kaspersky negó la descarga y dejó evento comprobable.
- La recolección de eventos Windows por Wazuh se observó; no debe confundirse «evento recibido» con «regla

  personalizada funcionando».
- La demostración permitió detectar riesgos de modificar local_rules.xml sin validación del archivo ni prueba de parsing;

  conviene respaldar, validar y reiniciar el servicio de modo controlado.
- Un artefacto EICAR representa un test de protección, no una brecha real. Se debe etiquetar como prueba autorizada.

11. Notificaciones y decisión de cierre

Para un evento de prueba de severidad Media se recomienda registrar la bitácora de laboratorio y comunicar el resultado al responsable del SOC académico. No hay constancia aportada de una notificación efectiva a gerencia ni motivos documentados para un aviso a autoridades. Cierre técnico sugerido: prueba contenida satisfactoriamente; la

eficacia de la regla personalizada requiere evidencia específica adicional, sin alterar la valoración del bloqueo local.

12. Anexos y cadena de evidencia

Referencia Prueba aportada por el estudiante EV-01 F03_14_Detalles_Deteccion_EICAR.png: navegador con bloqueo de descarga. EV-02 F03_14_Registro_Deteccion_EICAR.png: eventos del módulo de protección web.

EV-03 F03_19_Kaspersky_Evento_EICAR_Windows.png: PowerShell, evento ID 302. EV-04 Capturas del servidor Wazuh: lectura de /var/ossec/logs/archives/archives.json con eventos del canal Kaspersky. Control de fuente: los eventos EV-01 a EV-03 proceden de capturas del propio laboratorio; EV-04 se describe a partir de capturas

compartidas previamente. Las capturas se adjuntan como material demostrativo, no como certificado forense de cadena de custodia. Uso académico | Laboratorio de ciberseguridad defensiva Anexo D: EICAR C05 • 4

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6 EV-02: Protección web registró detección y descarga denegada. EV-03: Evento de Kaspersky ID 302 consultado desde PowerShell.

Fuente y límites de evidencia

Secciones conforme al Anexo D de la rúbrica original (pág. 83). Este informe se basa en pruebas registradas en la conversación y capturas del laboratorio del 21/10/2026; no reproduce como propios los datos, las cuentas ni los resultados del informe facilitado por

otros estudiantes. Uso académico | Laboratorio de ciberseguridad defensiva Anexo D: EICAR C05 • 5

Apéndice M: Playbook PB-01

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-01 | Fuerza bruta SSH / RDP

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar ataques de autenticación contra bastión Ubuntu, servicios internos y estaciones Windows sin afectar operaciones de pago.

02. Disparador, fuente y umbral

Wazuh: logs sshd/Windows Security; NGFW si registra intentos. Ventana operativa propuesta: ≥5 fallos en 5 min por IP contra un usuario, o ≥10 fallos/10 min contra varios usuarios.

03. Severidad inicial y promoción

Media; Alta cuando hay éxito posterior, IP interna lateral o bastión/servicio crítico; Crítica si se confirma uso no autorizado de privilegios.

04. Triage: validación paso a paso

1. Correlacionar IP, host y usuario en ventanas de 5, 10 y 30 minutos.

2. Diferenciar IP externa de redes de Operaciones, Gestión y VPN; cotejar lista de pruebas autorizadas.

3. Revisar autenticaciones exitosas posteriores, cambio de usuario y privilegios.

4. Comprobar exposición real de SSH/RDP y horarios operativos autorizados.

5. Consultar reputación de IP pública sin transferir registros sensibles.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-01 • 1 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Bloqueo temporal de IP externa por control autorizado con caducidad, o respuesta activa previamente aprobada.
- Solicitar al administrador TI bloqueo de cuenta no privilegiada en riesgo y verificar resultado.

06. Acciones no autorizadas a N1

- No reiniciar sshd/RDP en bastión ni deshabilitar cuentas privilegiadas.
- No bloquear subredes internas o la VPN sitio a sitio sin autorización.

07. Evidencia mínima preservada

- Evento Windows 4625 / 4624 o logs sshd; IP, usuario, host, intervalo y contador; IDs Wazuh.
- Resultado correlación de inicios exitosos; evidencia de regla de bloqueo y revocación.

08. Escalamiento obligatorio a N2

Acceso exitoso después de fallos, usuario privilegiado, bastión C05-SRV-01 o IP interna; confirmación de exposición crítica.

09. Criterios de cierre técnico

Se justificó prueba o ataque bloqueado, sin éxito ni desplazamiento; documentar acuse y recomendar MFA y VPN.

10. Mejora continua

Revisar falsos positivos por dispositivos de desarrollo macOS y listas de guardia.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-01 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-01 • 2

Apéndice N: Playbook PB-02

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-02 | Malware detectado por EDR

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Gestionar detecciones Kaspersky en Windows/macOS y distinguir pruebas EICAR de ejecución de malware real.

02. Disparador, fuente y umbral

Kaspersky: evento de amenaza y bloqueo. Wazuh puede recibir eventos Windows del canal Kaspersky Endpoint Security; la regla personalizada 100510 fue propuesta, no se confirmó su disparo.

03. Severidad inicial y promoción

Media si una muestra fue bloqueada en un equipo (incluida la prueba EICAR); Alta si se ejecuta, se repite o afecta activo crítico; Crítica ante ransomware activo o propagación.

04. Triage: validación paso a paso

1. Verificar resultado exacto: bloqueado, detectado, desinfectado, cuarentena o ejecución.

2. Registrar host, usuario, proceso, ruta, hash y canal de entrada (web/correo/USB).

3. Validar si el identificador EICAR-Test-File pertenece a prueba acordada.

4. Buscar mismo hash o nombre en otros agentes y activos de pago.

5. Revisar en Wazuh presencia del evento y separar ingestión de correlación personalizada.

05. Contención autorizada a N1

- Poner en cuarentena según política activa; conservar evidencia.
- Aislar endpoint si hay ejecución/propagación con severidad alta/crítica e informar a N2.

06. Acciones no autorizadas a N1

- No borrar evidencia, desactivar el EDR ni apagar el sistema sin instrucción.
- No informar infección real basándose únicamente en EICAR.

07. Evidencia mínima preservada

- Captura de Kaspersky «descarga denegada», módulo Protección frente a amenazas web.
- Evento Windows del proveedor avp, ID 302, 21/10/2026 11:34:05 (laboratorio observado).
- Registro Wazuh archivado de la fuente, con decoder/campo y regla efectivamente observada.

08. Escalamiento obligatorio a N2

Ejecución real, propagación, servidor afectado, imposibilidad de remediar o indicador de fraude/robo de credenciales.

09. Criterios de cierre técnico

Con amenaza bloqueada y sin ejecución, realizar análisis de comprobación y documentar limitaciones de correlación.

10. Mejora continua

Validar regla específica por eventchannel, sin duplicados ni modificación informal de políticas.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-02 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-02 • 2

Apéndice O: Playbook PB-03

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-03 | Cambio en archivos críticos (FIM)

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Controlar cambios en configuración de la API de pagos sin confundir despliegues autorizados con alteración maliciosa.

02. Disparador, fuente y umbral

Wazuh syscheck / FIM sobre /opt/pagoclaro/api/config/.env, rutas de despliegue y archivos de autenticación de Ubuntu. Umbral propuesto: cualquier cambio no autorizado en .env se revisa de inmediato.

03. Severidad inicial y promoción

Alta si archivo de producción modificado fuera de ventana o sin autorización; Crítica si hay extracción de secretos o web shell; Baja/Media ante cambio autorizado.

04. Triage: validación paso a paso

1. Identificar archivo, agente C05-SRV-03, hash anterior/posterior y tipo de cambio.

2. Cotejar ventana de despliegue y autorización de TI.

3. Consultar usuario/proceso de escritura cuando la telemetría lo permita.

4. Revisar cambios simultáneos en servicios, procesos y conexiones al núcleo transaccional.

5. Determinar si la diferencia compromete claves, endpoint o credenciales.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-03 • 1

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Preservar captura FIM y hash; avisar a responsable del API.
- Solicitar a N2 revisión del servicio; no editar ni restaurar archivo en N1.

06. Acciones no autorizadas a N1

- No revertir configuración ni reemplazar .env.
- No copiar al informe secretos ni tokens de pagos.

07. Evidencia mínima preservada

- syscheck: ruta, acción, integridad, hashes, usuario, hora, rule.id si aparece.
- Comparación de autorización/documentación de cambio sin exponer secretos.

08. Escalamiento obligatorio a N2

Cualquier cambio no autorizado a .env de la API, binarios o secretos en producción; sospecha de ejecución de código.

09. Criterios de cierre técnico

Validado cambio aprobado y hash esperado, o escalado con preservación de evidencia.

10. Mejora continua

Limitar rutas de FIM a activos críticos y añadir alertas sobre permisos y llaves.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-03 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-03 • 2

Apéndice P: Playbook PB-04

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-04 | Inicio de sesión VPN anómalo

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar acceso de administración por VPN desde país inusual al bastión o recursos de pago.

02. Disparador, fuente y umbral

Eventos del NGFW/VPN y Wazuh. Umbral propuesto: primer acceso administrativo desde país fuera de patrón, dos países en <60 min o IP nueva en horario inusual.

03. Severidad inicial y promoción

Alta si cuenta privilegiada/acceso remoto sin explicación; Crítica si se siguen consultas privilegiadas o cambios de claves; Media para viaje autorizado corroborado.

04. Triage: validación paso a paso

1. Verificar inicio exitoso y contexto del túnel VPN sitio a sitio frente a VPN de acceso remoto.

2. Comprobar usuario, MFA, IP pública, ASN y país estimado; geolocalización no es prueba concluyente.

3. Comparar historial de 30 días y turnos de guardia del usuario.

4. Contactar al titular por canal independiente, no por sesión sospechosa.

5. Revisar cambios de privilegio, transferencia de información y accesos a API/BD posteriores.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-04 • 1 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Solicitar cierre de sesión y rotación de credenciales a TI bajo procedimiento.
- Para cuenta no privilegiada, solicitar bloqueo preventivo ante falta de reconocimiento.

06. Acciones no autorizadas a N1

- No deshabilitar cuentas administrativas por cuenta propia.
- No bloquear sin análisis el túnel sitio a sitio de producción.

07. Evidencia mínima preservada

- VPN: hora, usuario, IP, MFA, país aproximado, gateway y sesión.
- Respuesta del titular y acciones inmediatamente posteriores.

08. Escalamiento obligatorio a N2

Cuenta administrativa, acceso no reconocido, múltiples accesos o acciones sensibles sobre BD/API.

09. Criterios de cierre técnico

Confirmación independiente de viaje o guardia; conservar aprobación y recomendaciones MFA.

10. Mejora continua

Líneas base geográficas y detección de viaje imposible ajustadas por VPN corporativa.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-04 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-04 • 2

Apéndice Q: Playbook PB-05

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-05 | Uso de USB no autorizado

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Impedir salida de información financiera tokenizada, identificadores y claves desde estaciones corporativas.

02. Disparador, fuente y umbral

Kaspersky Device Control en estaciones Windows/macOS compatibles. Umbral propuesto: conexión no autorizada siempre genera revisión; transferencia de datos sensibles eleva a Alta.

03. Severidad inicial y promoción

Baja si fue bloqueado sin copia; Media si se copió información; Alta si involucra llaves, informes financieros o reincidencia.

04. Triage: validación paso a paso

1. Distinguir dispositivo detectado, bloqueado o permitido.

2. Cotejar host, usuario y tipo/identificador de USB con inventario aprobado.

3. Revisar trazas de copia y volumen cuando existan; no asumir que hubo copia sólo por conexión.

4. Solicitar confirmación de propósito al usuario y autorización de TI.

5. Correlacionar detecciones antimalware en dispositivo y endpoint.

05. Contención autorizada a N1

- Solicitar retiro del dispositivo y mantener política de bloqueo.
- Notificar al responsable SOC ante exposición potencial de datos.

06. Acciones no autorizadas a N1

- No montar ni abrir el medio desconocido para inspección manual.
- No modificar controles ni excepciones de dispositivos.

07. Evidencia mínima preservada

- Evento de Device Control, host/usuario, identificador del medio, fecha y estado.
- Evidencia de copia sólo si el sistema realmente la registra.

08. Escalamiento obligatorio a N2

Copia de datos financieros, malware en USB o reincidencia de usuario con acceso sensible.

09. Criterios de cierre técnico

Dispositivo bloqueado y sin acceso a datos; educación y trámite formal de excepciones.

10. Mejora continua

Lista blanca de dispositivos con vencimiento y alertas DLP.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-05 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-05 • 2

Apéndice R: Playbook PB-06

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-06 | Phishing reportado

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar intentos de robo de credenciales de VPN, consola de pagos y correo de PagoClaro.

02. Disparador, fuente y umbral

Reporte del usuario o correo corporativo, análisis de cabeceras y eventos Kaspersky si hay descarga. Umbral: enlace/adjunto sospechoso con al menos un destinatario.

03. Severidad inicial y promoción

Baja si no hubo interacción; Media si clic/descarga; Alta si ingresó credenciales; Crítica si fue cuenta privilegiada comprometida.

04. Triage: validación paso a paso

1. Recopilar mensaje en formato .eml mediante proceso autorizado.

2. Verificar suplantación de proveedor de pagos, dominio, SPF/DKIM/DMARC y enlace sin abrirlo.

3. Preguntar si se ingresaron credenciales, se ejecutó archivo o se autorizó MFA.

4. Correlacionar con acceso VPN y alertas de protección web.

5. Comprobar cuántos destinatarios recibieron campaña sin difundir el contenido.

05. Contención autorizada a N1

- Instruir no interacción; pedir contención de dominio/URL a administrador.
- Solicitar cambio de contraseña y revocación de sesiones si hubo ingreso de credenciales.

06. Acciones no autorizadas a N1

- No abrir enlaces sospechosos en equipo de producción.
- No enviar .eml completo a verificadores públicos con datos personales.

07. Evidencia mínima preservada

- Cabeceras, remitente, hash/URL saneada, destinatarios y hora.
- Acciones del usuario confirmadas y alertas de protección web.

08. Escalamiento obligatorio a N2

Credenciales expuestas, ejecutable abierto, campaña masiva o suplantación de gerencia.

09. Criterios de cierre técnico

Se confirmó ausencia de interacción, se informó al usuario y se aplicó bloqueo preventivo autorizado.

10. Mejora continua

Refuerzo de verificación del proveedor y entrenamiento de personal de pagos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-06 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-06 • 2

Apéndice S: Playbook PB-07

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-07 | Escaneo de puertos y

reconocimiento Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Diferenciar barridos hacia API pública o servidores de un ejercicio autorizado.

02. Disparador, fuente y umbral

NGFW/IPS o Wazuh: muchas conexiones denegadas desde la misma IP. Umbral propuesto: ≥20 puertos distintos en 60 s o ≥100 conexiones denegadas/5 min.

03. Severidad inicial y promoción

Baja si bloqueo externo aislado; Media si repetido; Alta cuando proviene de VLAN interna o precede explotación del API.

04. Triage: validación paso a paso

1. Identificar IP fuente, destino, puertos y ventana del barrido.

2. Confirmar si la fuente es del auditor o escáner autorizado.

3. Verificar si hubo conexiones aceptadas o intentos de explotación.

4. Cruzar con alertas web, VPN y accesos de bastión.

5. Evaluar exposición del servicio y criticidad de API de pagos.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-07 • 1 PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Bloqueo temporal de IP externa maliciosa y registro de reversión.
- Solicitar análisis de origen a TI ante IP interna.

06. Acciones no autorizadas a N1

- No escanear de vuelta al origen.
- No aplicar bloqueos generalizados a rangos de proveedores de nube.

07. Evidencia mínima preservada

- Flujos / bloqueos NGFW, ventana, IP, puertos, permisos de regla y correlación.

08. Escalamiento obligatorio a N2

Origen interno, intento de explotación, API comprometida o servidor crítico como objetivo.

09. Criterios de cierre técnico

Reconocimiento externo bloqueado sin explotación; propuesta de endurecimiento de puertos.

10. Mejora continua

Ajustar umbral para excluir monitoreo legítimo sin crear puntos ciegos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-07 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-07 • 2

Apéndice T: Playbook PB-08

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-08 | Cuenta privilegiada nueva o

elevación Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar cuentas ADMIN, sudoers o roles superusuario de PostgreSQL no autorizados.

02. Disparador, fuente y umbral

Wazuh Windows EventChannel / Ubuntu auth y FIM; reglas locales de PostgreSQL. Umbral: cualquier grant de superusuario sin autorización se clasifica Alta.

03. Severidad inicial y promoción

Alta por defecto; Crítica cuando se confirma nueva cuenta privilegiada no autorizada en réplica/producción o abuso de llaves.

04. Triage: validación paso a paso

1. Revisar creación de cuenta, grupo/rol, emisor, usuario y sesión de origen.

2. Determinar el impacto del rol sobre C05-SRV-02 y base transaccional.

3. Verificar autorización previa y ventana de mantenimiento.

4. Consultar uso posterior de nueva cuenta, creación de tokens o alteración de permisos.

5. Cruzar con accesos anómalos y cambios FIM en archivos de aplicación.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-08 • 1

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Preservar logs y solicitar a administrador o N2 suspender privilegio no autorizado.
- Notificar al responsable SOC por amenaza potencial a datos financieros.

06. Acciones no autorizadas a N1

- No borrar usuario, revocar roles ni ejecutar SQL de reversión desde N1.
- No exponer secretos o volcado de datos de clientes para demostrar evidencia.

07. Evidencia mínima preservada

- Eventos de grupos/roles, sentencia saneada, hora, actor, activo y autorización.
- Registro de sesión y accesos posteriores.

08. Escalamiento obligatorio a N2

Siempre si no existe autorización documentada; de inmediato si es BD de pagos.

09. Criterios de cierre técnico

La autorización válida se adjunta y la actividad se clasifica como cambio aprobado; otros casos a N2.

10. Mejora continua

Auditar CREATE ROLE y membresías; MFA/PAM para administradores.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-08 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-08 • 2

Apéndice U: Playbook PB-09

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

PB-09 | Vulnerabilidad crítica

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva Control documental Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

Activo / ámbito 8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Priorizar CVE reales que afecten API pública, bastión, Ubuntu Server y librerías de pagos.

02. Disparador, fuente y umbral

Módulo de vulnerabilidades Wazuh y análisis de versión de paquetes. Umbral: CVSS crítico o explotación conocida con activo expuesto a Internet.

03. Severidad inicial y promoción

Media si CVE sin exposición; Alta con acceso desde Internet o explotación conocida; Crítica si hay explotación activa en componente transaccional.

04. Triage: validación paso a paso

1. Identificar CVE, paquete, versión y agente; confirmar que el software está presente.

2. Comprobar si el servicio está activo y expuesto en API o bastión.

3. Consultar fuentes oficiales del fabricante y disponibilidad de parche.

4. Verificar indicadores de explotación en eventos relevantes.

5. Calcular criticidad con impacto en pago, tokenización, llaves y continuidad.

Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-09 • 1

PAGOCLARO / C05 SOC NIVEL 1 • FASE 6

05. Contención autorizada a N1

- Notificar a TI y proponer mitigación aprobada (restricción de acceso, WAF/IPS).
- Programar revalidación posterior mediante escaneo autorizado.

06. Acciones no autorizadas a N1

- No instalar parches sin cambio aprobado.
- No ejecutar pruebas explotativas sobre la producción.

07. Evidencia mínima preservada

- CVE, versión, host, paquete, fuente y fecha de detección.
- Referencia de parche/mitigación y evaluación de exposición.

08. Escalamiento obligatorio a N2

Explotación activa, API expuesta con criticidad alta, ausencia de mitigación o CVE sin parche en activo crítico.

09. Criterios de cierre técnico

Verificar corrección con nuevo inventario/escaneo; registrar excepción formal si subsiste.

10. Mejora continua

Revisar parcheo de software crítico y ventanas de mantenimiento para pagos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros

sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-09 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no

detecciones que se haya comprobado activar. Uso académico | Laboratorio de ciberseguridad defensiva Playbook PB-09 • 2